



Auditoría General de la Nación

INFORME DE AUDITORÍA

**Sistema de Gestión y Análisis de la Deuda (SIGADE) y Sistemas Relacionados
MINISTERIO DE ECONOMÍA**

**Auditoría General de la Nación
Gerencia de Planificación y Proyectos Especiales
Departamento de Auditoría Informática**



Auditoría General de la Nación

Tabla de contenido

1. OBJETO DE AUDITORÍA.....	1
2. ALCANCE	1
2.1. EJECUCIÓN DEL TRABAJO DE AUDITORÍA	1
2.2. ENFOQUE DEL TRABAJO DE AUDITORÍA	2
2.3. PROCEDIMIENTOS DE AUDITORÍA.....	4
3. ACLARACIONES PREVIAS	6
3.1. EL SISTEMA DE GESTIÓN Y ANÁLISIS DE LA DEUDA (SIGADE)	6
3.2. MARCO NORMATIVO E INSTITUCIONAL.....	11
3.3. DESCRIPCIÓN DE LOS PROCESOS SUJETOS AL ANÁLISIS DE ESTA AUDITORÍA	17
4. HALLAZGOS	21
4.1. GOBIERNO DE TI	21
4.2. SEGURIDAD DE LA INFORMACIÓN	23
4.3. CONTINUIDAD DE LAS OPERACIONES ORGANIZACIONALES.....	29
4.4. OPERACIONES DE TI.....	33
4.5. ADQUISICIONES Y CONTRATACIÓN DE TI.....	34
4.6. SISTEMAS DE INFORMACIÓN.....	35
5. ANÁLISIS DE LA VISTA.....	41
6. RECOMENDACIONES	42
6.1. GOBIERNO DE TI	42
6.2. SEGURIDAD DE LA INFORMACIÓN	43
6.3. CONTINUIDAD DE LAS OPERACIONES ORGANIZACIONALES.....	44
6.4. OPERACIONES DE TI.....	44
6.5. ADQUISICIONES Y CONTRATACIÓN DE TI.....	44
6.6. SISTEMAS DE INFORMACIÓN.....	45
7. CONCLUSIONES.....	45
8. LUGAR Y FECHA	49
9. FIRMA	49
10. ANEXOS.....	50
ANEXO I – COMENTARIOS DEL AUDITADO.....	50
ANEXO II – ANÁLISIS DE LOS COMENTARIOS DEL AUDITADO.....	65



Auditoría General de la Nación

Glosario

ABM: Altas, Bajas y Modificaciones de usuarios en el sistema.

BCRA: Banco Central de la República Argentina.

BPM: Gestión de Procesos de Negocio, por sus siglas en inglés *Business Process Management*. Son buenas prácticas aplicadas para la optimización y mejora continua de los procesos de negocio.

CN: Constitución Nacional.

CobIT: Objetivos de Control para Información y Tecnologías Relacionadas, por sus siglas en inglés *Control Objectives for Information and Related Technology*. Se utiliza como marco de referencia de buenas prácticas en TI.

DADP: Dirección de Administración de la Deuda Pública.

DBA: Administrador de Base de Datos, por sus siglas en inglés *DataBase Administrator*.

DGTIC: Dirección General de Tecnologías de la Información y las Comunicaciones.

DRP: Plan de recuperación ante desastres, por sus siglas en inglés *Disaster Recovery Plan*.

e-SIDIF: Sistema Integrado de Información Financiera Internet.

GDE: Sistema de Gestión Documental Electrónica.

GUID: Guías INTOSAI.

IDI: Iniciativa de Desarrollo de INTOSAI.

INTOSAI: Organización Internacional de Entidades Fiscalizadoras Superiores, por sus siglas en inglés *International Organization of Supreme Audit Institutions*.

ISO: Organización Internacional de Normalización, por sus siglas en inglés *International Organization for Standardization*.

ISSAI: Normas Internacionales de las Entidades Fiscalizadoras Superiores, por sus siglas en inglés *International Standards of Supreme Audit Institutions*.

ITIL: Biblioteca de Infraestructura de Tecnologías de Información, por sus siglas en inglés *Information Technology Infrastructure Library*. Se utiliza como marco de referencia de buenas prácticas en TI.

ONCP: Oficina Nacional de Crédito Público.

SIDIF: Sistema Integrado de Información Financiera.



Auditoría General de la Nación

SIGADE: Sistema de Gestión y Análisis de la Deuda.

TI: Tecnologías de la Información.

UAI: Unidad de Auditoría Interna.

UNCTAD: Conferencia de las Naciones Unidas sobre Comercio y Desarrollo, por sus siglas en inglés *United Nations Conference on Trade and Development*.

WGITA: Grupo de Trabajo sobre Auditoría TI, por sus siglas en inglés *Working Group Information Technology Audit*.



Auditoría General de la Nación

INFORME DE AUDITORIA

Al Sr. Ministro de Economía
Dr. Martín Maximiliano Guzmán
S. / D.

En uso de las facultades conferidas por el artículo 118 de la Ley N° 24.156, la AUDITORÍA GENERAL DE LA NACIÓN efectuó un examen en el ámbito del MINISTERIO DE ECONOMÍA, con el objeto que se detalla en el apartado 1.

1. OBJETO DE AUDITORÍA

Sistema de Gestión y Análisis de la Deuda (SIGADE) y Sistemas Relacionados.

2. ALCANCE

2.1. Ejecución del Trabajo de Auditoría

El examen fue realizado de conformidad con las Normas de Control Externo Gubernamental y las Normas de Control Externo de la Gestión Gubernamental, aprobadas por Resoluciones AGN 26/15 y 186/16, respectivamente, dictadas en virtud de las facultades conferidas por el artículo 119 inciso “d” de la Ley N° 24.156 de Administración Financiera y de los Sistemas de Control del Sector Público Nacional, teniendo en cuenta el marco metodológico establecido en el “Manual de la IDI y del WGITA sobre auditorías de TI para las Entidades Fiscalizadoras Superiores”¹ y en la “GUID 5259 - Sistemas de

¹ <https://www.intosaicommunity.net/wgita/wp-content/uploads/2018/04/it-audit-handbook-spanish-version.pdf>



Auditoría General de la Nación

información sobre deudas públicas”², y aplicándose los procedimientos detallados en el punto 2.3.

El inicio de las tareas de auditoría se notificó al Ministerio de Economía mediante Nota N° 17/20-AG06, recibida el 04/08/2020.

El período auditado se extiende del 01/08/2018 al 31/07/2020.

Las tareas de campo se desarrollaron entre los meses de agosto 2020 a mayo de 2021, en forma remota por encontrarse en vigencia en el Área Metropolitana de Buenos Aires (AMBA) las medidas de Aislamiento Social Preventivo y Obligatorio (ASPO) establecidas por Dto. 297/20, y de Distanciamiento Social Preventivo y Obligatorio (DISPO) por Dto. 875/20 y sus respectivas normas modificatorias y complementarias.

2.2. Enfoque del Trabajo de Auditoría

La auditoría se desarrolló bajo un enfoque orientado a procesos y basado en riesgos, consistiendo en una revisión independiente y objetiva, para evaluar la eficacia, eficiencia, economía y aspectos de confidencialidad y seguridad de la información en la gestión integral de las Tecnologías de la Información y Comunicaciones (TICs) y los Sistemas de Información críticos del negocio (aplicaciones transaccionales/operacionales y de toma de decisiones de la organización) con el objetivo de detectar los riesgos potenciales (inherentes) que puedan causar el mayor impacto negativo en las operaciones de la organización auditada. Esta auditoría también verifica la operación y administración de los controles, la seguridad en los servicios de TI de la organización y el cumplimiento con las normas legales vigentes relacionadas con la información, los datos, el software y las redes de comunicaciones de datos. Para ello, el equipo de auditoría de TI se apoya en criterios, estándares y buenas prácticas de reconocimiento internacional que permiten identificar los

² <https://www.issai.org/pronouncements/guid-5259-public-debt-information-systems/>



Auditoría General de la Nación

riesgos, ponderar su probabilidad de ocurrencia y el nivel de impacto que estos riesgos tienen para la organización, como así también, se aplican estos criterios y estándares para establecer los desvíos existentes entre las prácticas aplicadas por el auditado y el “deber ser” según lo que estas buenas prácticas indican.³

La tarea abarcó la verificación de la gestión informática y de la gestión administrativa en las que intervienen el SIGADE y los sistemas relacionados, a cargo de la DGTIC y de la DADP respectivamente, soporte y mantenimiento continuo de la aplicación, la gestión de la infraestructura tecnológica y la disponibilidad del sistema para los usuarios internos y externos que interactúan con el aplicativo para las actividades de registración, seguimiento, control y consultas de los instrumentos de deuda pública durante todo su ciclo de vida.

Producto del relevamiento preliminar realizado y del análisis de riesgo resultante, se identificaron las siguientes cuestiones de auditoría como las más relevantes relativas al objeto de auditoría:

- Gobierno de TI;
- Seguridad de la Información;
- Continuidad de las Operaciones Organizacionales;
- Operaciones de TI;
- Adquisiciones y Contratación de TI;
- Sistemas de Información.

La auditoría tuvo en cuenta estándares internacionales establecidos como marco de referencia de buenas prácticas de TI, tales como CobIT versión 4.1, Normas ISO de la Serie 27000, Norma ISO 24.762 (Tecnologías de la información – Técnicas de seguridad - Directrices para los servicios de recuperación de desastres de las tecnologías de la

³ Fuente: ISACA (*Information Systems Audit and Control Association* - Asociación de Auditoría y Control de Sistemas de Información), asociación internacional que apoya y patrocina el desarrollo de metodologías y certificaciones para la realización de actividades de auditoría y control en sistemas de información.



Auditoría General de la Nación

información y comunicaciones) e ITIL versión 4, entre otras. Éstas describen los procedimientos que una organización debe implementar para obtener resultados óptimos en la gestión de la información.

Los procedimientos de auditoría ejecutados se exponen a continuación, desagregados por cuestión de auditoría.

2.3. Procedimientos de Auditoría

Gobierno de TI:

- análisis de documentación relativa a diagnóstico de situación de las áreas relacionadas con el objeto de auditoría;
- verificación de la existencia y periodicidad y análisis de contenido de los informes evaluatorios del control interno por parte de la auditoría interna, especialmente de TI.

Seguridad de la información:

- constatación del plan de seguridad de la información del organismo y evaluación respecto de su formalidad, vigencia y cobertura;
- estudio de la estructura organizacional del área de seguridad de la información del organismo, suficiencia y diseño de las misiones y funciones establecidas y verificación de la separación de funciones;
- evaluación de la gestión de usuarios del SIGADE en términos de ABM, política de claves y permisos otorgados según las funciones que le corresponden a cada perfil de usuario;
- análisis de la seguridad de la red implementada en el ámbito del SIGADE;
- estudio de los procedimientos de evaluación y monitoreo de las pistas de auditoría y análisis de las tablas de auditoría aplicados.

Continuidad de las operaciones organizacionales:



Auditoría General de la Nación

- apreciación del plan de recuperación ante desastres, verificando que se prueba y se actualiza con regularidad, y que cumple con la cobertura operacional requerida por la organización;
- análisis de las políticas y procedimientos de respaldo de la información (*backup*), en especial sobre las prácticas utilizadas sobre el entorno del SIGADE, y verificación de las pruebas de restauración implementadas, a fin de comprobar la integridad de las copias.

Operaciones de TI:

- evaluación de los procedimientos e instrucciones de operación implementados por la DADP y la DGTIC en el ámbito del SIGADE y manuales de procesos relacionados.

Adquisiciones y contratación de TI:

- verificación y análisis de los acuerdos de niveles de servicio pactados con los proveedores, en especial con el proveedor del servicio de soporte y mantenimiento del SIGADE, la UNCTAD.

Sistemas de información:

- evaluación de la integración del SIGADE y otros sistemas relacionados con los procedimientos y herramientas ofimáticas utilizadas por la DADP;
- análisis de los mecanismos de control de entrada de datos primarios y complementarios al SIGADE;
- verificación de los controles de salida de la información utilizados, a nivel de interfaz de usuario del SIGADE, evaluando que garanticen la integridad y exactitud de los datos;
- evaluación de las actividades y funciones habilitadas al/los administrador/es del sistema y de la base de datos productiva.



Auditoría General de la Nación

3. ACLARACIONES PREVIAS

3.1. El Sistema de Gestión y Análisis de la Deuda (SIGADE)⁴

En la década del 90 la Argentina realiza una profunda reforma de la administración financiera del Estado Nacional, siendo el sistema de presupuesto la base estructural de la transformación de las finanzas públicas.

A partir de la sanción de la Ley marco de la Administración Financiera y de los Sistemas de Control del Sector Público Nacional N° 24.156, surge la necesidad de documentar los desarrollos conceptuales y metodológicos relacionados con la formulación, ejecución y evaluación del presupuesto público, así como también de los aspectos operativos del proceso presupuestario. Y para dar soporte a estos nuevos modelos de gestión se requiere desarrollar e implementar sistemas de información que estén a la altura de estos desafíos, tanto a nivel operacional y administrativo como en la toma de decisiones.

La administración del Crédito Público⁵ fue parte de este proceso de transformación y para afrontarlo en 1993, conjuntamente con la sanción de la Ley N° 24.156, el Estado argentino firmó el primer acuerdo con la UNCTAD para llevar a cabo la ejecución del proyecto “Creación del registro y fortalecimiento de la gestión de la deuda pública en la República Argentina” con el objetivo de contar en el menor tiempo posible con información relativa a la deuda pública de manera confiable y oportuna, alineado con lo establecido en la ley.

Con la ejecución del proyecto, a fines de 1993 se implementó el Sistema de Gestión y Análisis de la Deuda (SIGADE), versión 4.0 en el ámbito de la DADP dependiente de la

⁴ Parte de la información aquí vertida fue obtenida del documento de capacitación “Sistema de Crédito Público - CAPACITACIONECONOMIA”

(http://capacitacion.mecon.gob.ar/manuales_nuevo/Credito_Sistema_Credito_Publico.pdf) [Fecha de entrada: 25/03/2021], de la información entregada por la DADP y del manual de usuarios del SIGADE versión 6 – UNCTAD.

⁵ Se entiende por Crédito Público a la capacidad que tiene el Estado para endeudarse con el objeto de captar medios de financiamiento.



Auditoría General de la Nación

ONCP, órgano rector del sistema de crédito público y fuente de información de la deuda pública para todos los usuarios del Estado Nacional competentes en el acceso a esta información.

Conjuntamente con la UNCTAD, la ONCP ha avanzado en distintos planes de actualización del software, por ejemplo: i) la implementación de una solución informática que permitió la integración entre el SIGADE y el SIDIF para el intercambio de información entre ambos aplicativos; ii) la integración del SIGADE con otros sistemas utilizados por el Ministerio de Economía; iii) los procesos de migración a nuevas versiones del SIGADE de acuerdo al plan evolutivo establecido por la UNCTAD; y iv) la implementación y formalización de procedimientos establecidos por la DADP para ejecutar controles sobre la información cargada por los usuarios autorizados en el sistema, para cada instrumento de deuda, entre otros.⁶ Al momento de esta auditoría se encuentra en producción la versión 6.1.4.1 del SIGADE.

El SIGADE está concebido para ayudar a los países a gestionar su deuda pública externa e interna. El sistema gestiona las obligaciones de deuda, como las contraídas o garantizadas por el Estado o las reasignadas, así como las donaciones y las reestructuraciones. También puede utilizarse para realizar el seguimiento de la deuda externa privada sin garantía. Según datos publicados por la UNCTAD, el Programa ha suministrado sus productos y servicios a 105 instituciones de 69 países⁷.

El SIGADE tiene por objetivo satisfacer las necesidades operativas y analíticas de una oficina de gestión de la deuda pública, ya sea como *front office* (emisión de títulos de deuda), *middle office* (análisis) o *back office* (operaciones de registro y gestión).

⁶ Expediente de aprobación del proyecto UNCTAD, Memorando ONCP N° 384-2008, Ministerio de Economía y Producción.

⁷ https://unctad.org/es/system/files/official-document/gdsdmfasmisc2011d1_sp.pdf;
<https://unctad.org/es/system/files/official-document/pogiddms17r7.sp.pdf> (Fecha de entrada: 25/03/21)



Auditoría General de la Nación

El sistema permite a los administradores de la deuda realizar las siguientes operaciones:

- Registrar la información relativa a préstamos, donaciones y títulos de deuda, incluida su eventual relación con proyectos y cuentas presupuestarias nacionales.
- Crear y actualizar automáticamente los desembolsos estimados.
- Calcular automáticamente las tablas de amortización.
- Registrar los giros reales, las colocaciones reales y las operaciones del servicio de la deuda.
- Identificar los préstamos con atraso en el servicio de la deuda y calcular los intereses por mora.
- Elaborar una amplia gama de informes estándares y personalizados, incluidos reportes para boletines estadísticos o informes con fines de validación y control.
- Analizar la cartera y formular estrategias en materia de deuda.

Los principales módulos que componen el sistema son los siguientes:

- **Acuerdos Generales:** Registra los datos básicos de los acuerdos generales que abarcan varios instrumentos individuales. Puede configurar un vínculo entre un acuerdo general y los acuerdos que se deriven de éste.
- **Registro de Préstamos:** Los usuarios introducen información general relativa al acuerdo de préstamo, como las partes intervinientes, el número de referencia y la fecha de firma; e información específica, como las condiciones del principal, los intereses y comisiones.
- **Títulos de Deuda:** Se basa en un enfoque por instrumentos. Se utiliza para registrar todos los tipos de títulos de deuda de corto y largo plazo.
- **Deuda de Corto Plazo:** Está específicamente concebido para registrar datos agregados de deuda externa de corto plazo (con vencimiento original menor o igual a un año); también permite la introducción manual o las importaciones desde planillas de cálculo.



Auditoría General de la Nación

- **Deuda Externa Privada sin Garantía:** Permite a los usuarios introducir datos agregados en dos modalidades: introducción manual o importaciones desde planillas de cálculo.
- **Servicio de la Deuda:** Se utiliza para registrar los períodos presupuestarios y los montos asignados correspondientes. Fue concebido para instituciones que desean o necesitan establecer un vínculo entre los pagos del servicio de la deuda y su sistema presupuestario.
- **Subastas:** Se utiliza para registrar las ofertas de instrumentos del mercado monetario, así como de bonos y pagarés sobre una base de precio único o múltiple.
- **Reorganización de Deuda:** Puede tratar todos los tipos de reestructuración de deuda, como la refinanciación, el reescalonamiento, la condonación, la conversión y los pagos anticipados o recompras. El módulo trata todas las fases de la reorganización y mantiene una relación entre la deuda anterior y la nueva deuda.
- **Autorizaciones de Emisión:** Permite controlar las emisiones de títulos de deuda o de *Sukuk*⁸ en contraste con el monto autorizado o el asignado en el Plan Anual del Presupuesto, y hacer un seguimiento de los montos que quedan disponibles.
- **Auditoría:** Desde el panel de control del sistema, ofrece un amplio dispositivo de rastreo de todas las operaciones de la base de datos realizadas por los usuarios, así como de las modificaciones de operaciones y datos registrados. Puede ayudar al organismo a producir pistas de auditoría con información sobre qué personas han accedido al sistema y su nivel de acceso, reforzando así la seguridad de los datos.
- **Seguridad:** Permite a los administradores del sistema configurar los derechos de acceso de usuarios a las funciones que le fueran oficialmente conferidas según su perfil. Se implementa la seguridad a través de la creación y administración de usuarios y grupos de usuarios, así como mediante la asignación de derechos o restricciones que les caben.

⁸ Los *Sukuk* (plural de *sakk*) son certificados de inversión que cumplen con las normas y principios islámicos (*sharia*). Frecuentemente se les denomina obligaciones o valores islámicos. Como instrumentos financieros islámicos, los *Sukuk* no pagan intereses, sino que generan rendimientos de un activo no financiero (el activo subyacente). (Manual de Usuario SIGADE v6, p. 175)

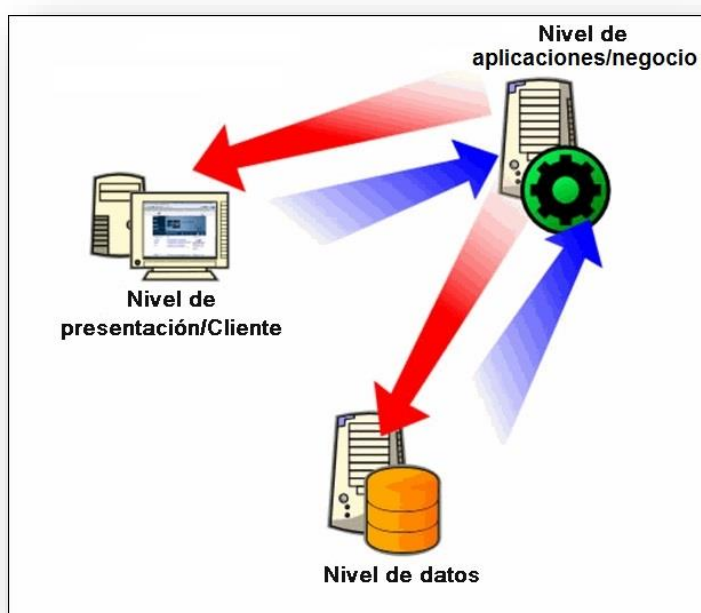


Auditoría General de la Nación

El SIGADE versión 6 está habilitado para la Web, por lo que puede accederse a él a través de un navegador de internet, es decir, desde una ubicación remota. Fue diseñado con una arquitectura de tres niveles, de modo que la interfaz de usuario, el proceso funcional (“reglas de negocios”), y el almacenamiento y acceso a los datos se desarrollaron y conservaron como módulos independientes:

- El nivel de presentación o interfaz es utilizado por el usuario. Muestra información referente a servicios o transacciones y envía resultados a los demás niveles.
- El nivel de lógica de negocios controla la funcionalidad de la aplicación mediante un procesamiento detallado.
- El nivel de datos consta de servidores de bases de datos licenciadas. Aquí es donde se almacena y recupera la información. Este nivel mantiene los datos independientes de servidores de aplicaciones o lógica de negocios.

Ilustración N°1 – Composición de los tres niveles de la arquitectura del SIGADE vers. 6



Fuente: manual de usuario del SIGADE v.6 - UNCTAD



Auditoría General de la Nación

Al momento de la ejecución de esta auditoría, el SIGADE prestaba servicios a un total de 49 usuarios que se distribuyen de la siguiente manera: 43 de la ONCP; 2 de Auditoría Interna (UAI); 1 de la Dirección General de Sistemas de Información de Administración Financiera (DGSIAF)⁹; 1 de Naciones Unidas (UNCTAD) y 2 del Congreso Nacional, en un entorno llamado “SIGADE Imagen”.¹⁰

3.2. Marco normativo e institucional

Nuestra Constitución Nacional establece cuáles son los recursos del Tesoro de la Nación (Art. 4, CN), permitiéndole al Gobierno Federal obtener créditos, tanto de orden interno como externo, y admitiendo excepcionalmente el endeudamiento del país para el caso de urgencias (guerras, desastres naturales, inundaciones, etc.) y para empresas de utilidad nacional (construcción de obras civiles, programas de saneamiento financiero, mejora de los distintos sectores gubernamentales, etc.). Es el Congreso quien tiene la potestad de contraer empréstito de dinero sobre el crédito de la Nación (Art. 75, inc. 4, CN)

La Ley de Administración Financiera N° 24.156¹¹ (LAF), que resulta de aplicación obligatoria a todos los organismos del Sector Público Nacional (Art. 8, LAF) y los que se incluyan en el clasificador institucional del Sector Público Nacional, define al crédito público como “la capacidad que tiene el Estado de endeudarse con el objeto de captar medios de financiamiento para realizar inversiones reproductivas, para atender casos de evidente necesidad nacional, para reestructurar su organización o para refinanciar sus pasivos, incluyendo los intereses respectivos”. No podrá realizar acciones de crédito

⁹ Área que administra el e-SIDIF.

¹⁰ Información provista por la Dirección de Explotación, dependiente de la Dirección General de Tecnologías de la Información y las Comunicaciones del Ministerio de Economía.

¹¹ <http://servicios.infoleg.gob.ar/infolegInternet/anexos/0-4999/554/texact.htm> (Fecha de entrada: 25/03/2021)



Auditoría General de la Nación

público para financiar gastos operativos. (Art. 56, LAF)¹²

Se consideran gastos operativos a aquellas erogaciones de la Administración Nacional incluidas como “Gastos de Consumo” en el Clasificador Económico del Gasto. No se considerarán gastos operativos los destinados a ejecutar programas de asistencia técnica financiados por Organismos Multilaterales de Crédito (Decreto N° 1344/07).¹³

Ninguna entidad del Sector Público Nacional podrá iniciar trámites para realizar operaciones de crédito público sin la autorización previa del órgano coordinador de los sistemas de administración financiera (Art. 59, LAF).

A su vez establece que las entidades de la Administración Nacional no podrán formalizar ninguna operación de crédito público que no esté contemplada en la ley de presupuesto general del año respectivo o en una ley específica, excepto créditos suscritos con organismos financieros multilaterales de los que Argentina es miembro, en donde se habilita al Poder Ejecutivo (PE) a formalizar las operaciones de crédito. (Art. 60, LAF)

Nuestra legislación establece cómo se clasifica y se compone la deuda pública.

Según el ámbito de exigibilidad:

- La deuda interna es aquella contraída con personas físicas o jurídicas residentes o domiciliadas en la República Argentina y cuyo pago puede ser exigible dentro del territorio nacional.
- La externa es la contraída con otro Estado u organismo internacional o con cualquier otra persona física o jurídica sin residencia o domicilio en la República Argentina y cuyo pago puede ser exigible fuera de su territorio.

¹² https://capacitacion.mecon.gob.ar/manuales_nuevo/Credito_Sistema_Credito_Publico.pdf (Fecha de entrada: 25/03/2021)

¹³ <http://servicios.infoleg.gob.ar/infolegInternet/anexos/130000-134999/133006/texact.htm> (Fecha de entrada: 25/03/2021)



Auditoría General de la Nación

En los casos que las operaciones de crédito público originen la constitución de deuda pública externa, antes de formalizarse el acto respectivo y cualquiera sea el ente del Sector Público emisor o contratante, deberá emitir opinión el BCRA sobre el impacto de la operación en la balanza de pagos. (Art. 61, LAF)

Y según la naturaleza del deudor, la deuda puede ser:

- Directa, que es aquella asumida por la Administración Central en calidad de deudor principal; o
- Indirecta, que es la constituida por cualquier persona física o jurídica, pública o privada, distinta de la Administración Central, pero que cuenta con su aval, fianza o garantía. (Art. 58, LAF)

Asimismo, la ley también clasifica la deuda por el tipo de operación por el cual fue contraída y que puede originarse por los siguientes instrumentos:

- a) La emisión y colocación de títulos, bonos u obligaciones de largo y mediano plazo, constitutivos de un empréstito.
- b) La emisión y colocación de Letras del Tesoro cuyo vencimiento supere el ejercicio financiero. Estos tipos de instrumentos originan el instrumento de deuda denominado “Título público”, que constituyen las obligaciones de mediano y largo plazo contraídas por el Estado Nacional, con el objeto de captar fondos del mercado de capitales.
- c) Los préstamos con instituciones financieras y obras, servicios o adquisiciones cuyo pago total o parcial se estipula realizar en el transcurso de un ejercicio financiero posterior al vigente.

Este tipo de operaciones configuran un instrumento de deuda que se denomina “préstamos”: son todas aquellas operaciones de financiamiento de mediano y largo plazo asumidas por el Estado Nacional en su carácter de deudor principal, y que generalmente están orientados a fines específicos que se establecen en el contrato o convenio respectivo.



Auditoría General de la Nación

- d) Los avales otorgados por el Estado Nacional por operaciones de crédito público interno o externo, son considerados deuda indirecta, pudiendo ser beneficiarios de los mismos las empresas públicas, privadas o mixtas, los organismos del Estado de cualquier naturaleza, las provincias y los organismos paraestatales de jurisdicción nacional, provincial o municipal.
- e) La consolidación, conversión y renegociación de otras deudas son operaciones que configuran lo que genéricamente se denomina “reestructuración de la deuda” por las cuales no se contrae mayor endeudamiento, sino que produce una modificación en la estructura de pasivos en términos de montos, plazos, servicios de la deuda o rendimientos con el fin de obtener una mejora en las condiciones de financiamiento, o una disminución en la vulnerabilidad del sector externo ante fluctuaciones en los tipos de cambio y las tasas de interés internacionales.

No se considera deuda pública del Tesoro las operaciones que emita el Tesoro para cubrir deficiencias estacionales de caja, hasta el monto que fije anualmente la ley de presupuesto general. Estas letras emitidas deben ser reembolsadas durante el mismo ejercicio financiero. (Art. 82, LAF)¹⁴

Las principales funciones de la ONCP son las siguientes:

- a) Participa en la formulación de los aspectos crediticios de la política financiera que, para el Sector Público Nacional, elabore el órgano coordinador de los sistemas de administración financiera.
- b) Organiza un sistema de información sobre el mercado de capitales de crédito.
- c) Tramita las solicitudes de autorización para iniciar operaciones de crédito público.
- d) Mantiene un registro actualizado sobre el endeudamiento público, debidamente integrado al sistema de contabilidad gubernamental.

¹⁴ https://capacitacion.mecon.gob.ar/manuales_nuevo/Credito_Sistema_Credito_Publico.pdf (Fecha de entrada: 25/03/2021)



Auditoría General de la Nación

e) A través de los Reglamentos parciales N° 1 y N° 3 de la Ley N° 24.156 según Decretos Nros. 2662/92 y 1361/94, entre otras funciones, se le agrega a la ONCP, establecer un procedimiento mediante el cual los entes emisores y contratantes de deuda pública deberán comunicarle a la Oficina mencionada el o los desembolsos que realicen. Y a los fines de mantener actualizado el registro de las operaciones públicas, todas las jurisdicciones y entidades del Sector Público Nacional no Financiero deben atender a los requerimientos de información relacionados con el mencionado registro, en el plazo que establece el decreto o en los que establezca la ONCP. También prevé, que ésta será quien dicte las normas específicas y mecanismos de uso obligatorio, relacionadas con el registro de la deuda pública directa y de aquella garantizada por la administración central acorde a los procedimientos que dicte la Contaduría General de la Nación, para su integración a los sistemas de contabilidad gubernamental y unidad de registro de crédito público, respectivamente, y dentro del marco del Sistema Integrado de Información Financiera. (Decreto N° 1344/07. Reglamento de la Ley N° 24.156)¹⁵

La dirección y supervisión del Sistema de Crédito Público es realizada por la Secretaría de Finanzas, asistida por las Subsecretarías que la integran (Art. 5, Decreto N° 820/2020), tiene la facultad de redistribuir o reasignar los medios de financiamiento obtenidos mediante operaciones de crédito público, siempre que así lo permitan las condiciones de la operación respectiva y las normas presupuestarias. (Art. 67, LAF)

Ésta fijará y determinará la oportunidad y características financieras de los instrumentos de crédito público mencionados en el Art. 57 de la ley correspondiente a las emisiones y colocaciones de la Administración Central, y procederá a su emisión en los términos, a los fines y por hasta las sumas estipuladas en la Ley de Presupuesto del ejercicio fiscal de que se trate o en una ley específica, y realizará dichas operaciones para lo cual queda facultado, entre otras cosas, para:

¹⁵ <http://servicios.infoleg.gob.ar/infolegInternet/anexos/130000-134999/133006/texact.htm> (Fecha de entrada: 25/03/2021)

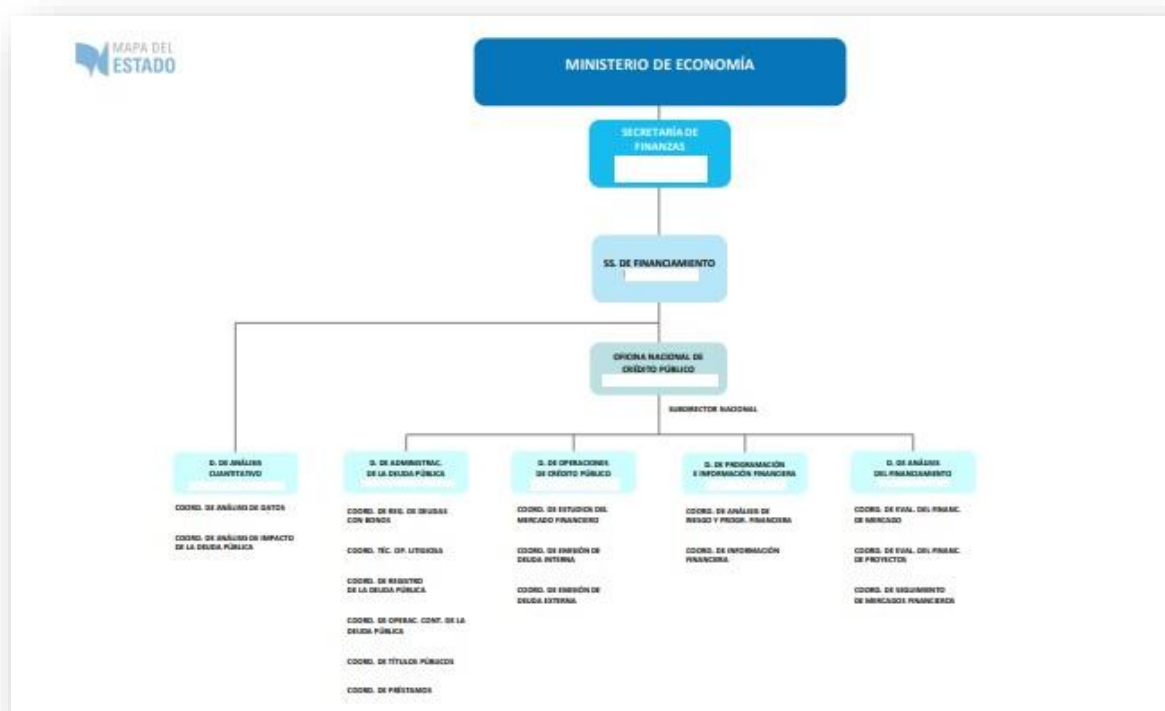


Auditoría General de la Nación

- a) Determinar el valor nominal de las operaciones, la moneda en que serán denominadas, las fechas de emisión y de vencimiento, la tasa de interés aplicable, su periodicidad y forma de cálculo, los mercados del país o del exterior en el que se ofrecerán y se cotizarán, y la disposición de su rescate anticipado.
- b) Designar instituciones financieras que representen y se encarguen de la organización de las operaciones de crédito público de que se trate.
- c) Celebrar con organismos del exterior, entidades financieras, mercados autorregulados y organizaciones de servicios de información y compensación de operaciones financieras, o con cualquier otra persona física o jurídica del país o del exterior, todos los acuerdos o contratos necesarios para la registración y/o colocación y/o venta de las operaciones involucradas.
- d) Acordar las condiciones por las que las instituciones financieras colocadoras se obligan a adquirir los instrumentos que se ofrezcan y a colocarlos en el mercado y los mecanismos de información sobre el método de colocación de los bonos respectivos, la asignación de las órdenes de compra entre los distintos participantes y otras decisiones relevantes vinculadas con el funcionamiento del mercado.



Auditoría General de la Nación



Fuente: organigrama obtenido de la página oficial de la Jefatura de Gabinete de Ministros¹⁶

3.3. Descripción de los procesos sujetos al análisis de esta auditoría

Los principales procesos de control del SIGADE que fueron motivo de análisis en función del objeto de auditoría establecido son:

- **Gobernabilidad de TI:** Evaluación de la gestión de la DGTIC para asegurar un adecuado ambiente tecnológico sobre el SIGADE y su ajuste a las necesidades organizacionales. Entre los procesos a cargo de la DGTIC se encuentra el mantenimiento del sistema, la gestión de la infraestructura tecnológica (servidores, bases de datos, resguardo de la información y comunicaciones), el soporte funcional a la comunidad usuaria, la gestión de incidencias y problemas sobre el aplicativo,

¹⁶ <https://mapadeleestado.jefatura.gob.ar/organigramas/005.pdf> (Fecha de entrada: 25/03/2021)



Auditoría General de la Nación

la gestión de los servicios de terceros, la seguridad de la información y el plan de contingencia.

- **Procesos Implementados por la DADP:** Para la gestión del ciclo de vida de los instrumentos de deuda más aplicados por el sistema de financiamiento del estado, se siguen los siguientes procesos:
 - **Procesos de Administración de Préstamos:** Comprende desde que la DADP recibe el Contrato, Decreto o Resolución que aprueba la operación, la atención de los correspondientes servicios financieros, hasta la cancelación de la obligación, incluyendo su registro en el SIGADE y en la contabilidad.
 - **Procesos de Administración de Títulos Públicos:** Comprende desde la recepción en la DADP de las actuaciones informando la ejecución de una operación de crédito público con títulos públicos o Letras del Tesoro, en ambos casos con la documentación de respaldo correspondiente, hasta la cancelación íntegra de la obligación, incluyendo su registro en el SIGADE y en la contabilidad.
- **Relación del SIGADE con otros sistemas del organismo¹⁷:**
 - **SIDIF-LINK:** es un sistema de interfaz de datos destinado a la transmisión de información entre el SIGADE y el e-SIDIF. La interfaz permite, a través de sus módulos de Recursos y Gastos, ejecutar el presupuesto asignado a la deuda pública y generar los Formularios de Ingresos y de Gastos para su reflejo en la Contabilidad Pública. SIDIF-Link es un producto desarrollado internamente en el Ministerio de Economía que se encuentra operativo desde 1997¹⁸.

¹⁷ Información provista por la Dirección General de Tecnologías de la Información y las Comunicaciones del Ministerio de Economía y por la DADP.

¹⁸ En noviembre de 2020, luego de una fase de pruebas, el organismo implementó la vinculación automática entre el SIGADE y el e-SIDIF para confeccionar los comprobantes relacionados con los módulos de Recursos y Gastos (órdenes de pago y vencimientos). Desde la puesta en marcha de esta interoperabilidad entre el SIGADE y el e-SIDIF, el SIDIF-Link se utiliza únicamente para la carga de los tipos de cambio y para generar reportes de consultas.



Auditoría General de la Nación

- **Sistema de Regularización de la Deuda Pública (SRDP):** Registra el seguimiento de los formularios de requerimiento de pago (FRP) recibidos por cada organismo y que corresponden a acreedores a los cuales se deberá pagar deuda consolidada. Prevé el pago con distintas modalidades (efectivo y bonos de diferentes características). El SRDP permite generar los procedimientos para instruir a la Caja de Valores para que realice los pagos y prepare la información que va a ser enviada electrónicamente a través de una Red Privada Virtual¹⁹. SRDP registra automáticamente en el SIGADE la colocación instruida a Caja de Valores. Posee un módulo de digitalización de documentación y las consultas pueden ser visualizadas en formato PDF. SRDP es una aplicación desarrollada internamente en el Ministerio de Economía.
- **Base Access:** Esta base de datos es administrada por la Coordinación de Seguimiento de Mercados Financieros, y contiene datos obtenidos del sistema de información financiera (REUTERS) utilizados para actualizar las tablas del SIGADE en lo que se refiere a tasas de interés vigentes en el mercado internacional, el valor del Coeficiente de Estabilización de Referencia (CER) y los tipos de cambio de las monedas extranjeras en que se encuentre nominada la deuda pública.
- **Sistema de Información Financiera Internet (e-SIDIF):** Es un software desarrollado por el Ministerio de Economía con el objeto de cubrir el proceso de gastos del Estado Nacional de forma integral, desde la formulación presupuestaria hasta la rendición de cuentas. Cuenta con módulos que proveen las herramientas informáticas necesarias para estimar el gasto de cada organismo, cargar órdenes de pago, vincular las facturas con las fuentes de financiación, y exportar la información anual de forma de poder confeccionar el Informe de Cuenta de Inversión, la herramienta de rendición de cuentas que

¹⁹ Una red privada virtual (RPV) (en inglés, *Virtual Private Network*, VPN) es una tecnología de red de computadoras que permite una extensión segura de la red de área local (LAN, *Local Area Network*) sobre una red pública o no controlada como Internet. Permite que la computadora en la red envíe y reciba datos sobre redes compartidas o públicas como si fuera una red privada, con toda la funcionalidad, seguridad y políticas de gestión de una red privada.



Auditoría General de la Nación

es elevada al Congreso Nacional. El sistema no es autónomo, para cumplir con el flujo completo de sus procesos se apoya en una serie de subsistemas (como el que permite registrar recursos propios, e-recauda) y mediante la interoperabilidad con otros sistemas como el SIGADE a través de *Web Services*²⁰ para el intercambio de formularios. A su vez, sirve como fuente de información para otra serie de sistemas, como por ejemplo el portal “Presupuesto Abierto”.

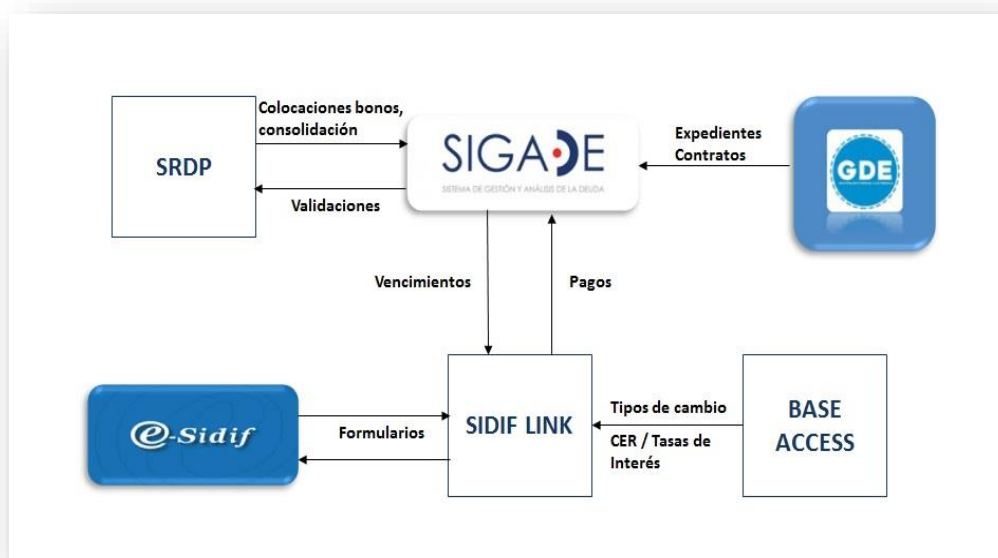
- **Sistema de Gestión Documental Electrónica (GDE):** Es el sistema integrado de caratulación, numeración, seguimiento y registración de movimientos de todas las actuaciones y expedientes del Sector Público Nacional, actuando como plataforma para la gestión de expedientes electrónicos. No existe una vinculación automática entre GDE y SIGADE, por ende, la DADP toma del GDE los expedientes que contienen los distintos actos administrativos, contratos, documentos de trabajo, etc., que corresponden a los instrumentos de deuda a registrar en el SIGADE. En el SIGADE se carga manualmente la información técnica del instrumento de deuda a gestionar, que surge de los documentos extraídos del GDE.

²⁰ Un servicio web (en inglés, *web service* o *web services*) es una tecnología que utiliza un conjunto de protocolos y estándares que sirven para intercambiar datos entre aplicaciones. Distintas aplicaciones desarrolladas en lenguajes de programación diferentes, y ejecutadas sobre cualquier plataforma, pueden utilizar los servicios web para intercambiar datos en redes de computadoras como Internet. La interoperabilidad se consigue mediante la adopción de estándares abiertos.



Auditoría General de la Nación

Ilustración N°2 - Interoperabilidad entre los sistemas:



Fuente: elaboración propia en base a la información provista por la DGTIC y la DADP

4. HALLAZGOS

4.1. Gobierno de TI

4.1.1. La DGTIC no ha realizado un relevamiento integral de los activos de TI, los procesos, las necesidades y el nivel de satisfacción de los usuarios en el ámbito de la DADP. Esta situación conduce al desconocimiento de la opinión de los usuarios respecto a los problemas, debilidades y requerimientos funcionales y técnicos del SIGADE, y del nivel de satisfacción de los usuarios con el sistema y la calidad de los servicios de TI brindados por la DGTIC y por la UNCTAD.

En base al análisis de la documentación provista y de las entrevistas mantenidas con las áreas de servicio de la DGTIC y con las principales áreas operativas de la DADP, se verificó que la DGTIC no realiza relevamientos con la comunidad usuaria vinculada al entorno SIGADE, sobre los procesos operativos ejecutados, las reglas de negocio, las



Auditoría General de la Nación

necesidades funcionales y tecnológicas de los usuarios de las distintas coordinaciones integrantes de la DADP, ni de los niveles de satisfacción del servicio de TI brindado por la DGTIC y del servicio de soporte y mantenimiento continuo del SIGADE a cargo de la UNCTAD.

Las buenas prácticas referidas a la gestión de usuarios indican que los relevamientos y encuestas de satisfacción de los usuarios respecto de requerimientos funcionales y tecnológicos y de los niveles de servicios de TI brindados constituyen una herramienta de vital importancia para realizar las acciones correctivas, evolutivas y adaptativas sobre los servicios de TI y las aplicaciones de acuerdo a los requerimientos dinámicos del negocio (ITIL - fase: Operación del Servicio y CobIT v4.1 - DS8: Administrar la Mesa de Servicio y los Incidentes y - DS10: Administración de Problemas).

Que no se realicen y documenten estos relevamientos impacta en el nivel de conocimiento de la DGTIC sobre los problemas y las necesidades técnicas y funcionales de los usuarios del SIGADE, ocasionando que no se tomen acciones correctivas, evolutivas y adaptativas de manera planificada sobre el sistema como parte de un plan formalizado de mejora continua, esto último tiene vinculación directa con lo indicado en los hallazgos 4.5.1 y 4.6.1.

4.1.2. *El SIGADE no cuenta, para su plataforma tecnológica y para los servicios de soporte y mantenimiento continuo brindados por la DGTIC, con un adecuado ambiente de control interno que garantice la detección temprana de riesgos de TI y las acciones pertinentes para mitigarlos.*

A partir de las entrevistas mantenidas y del análisis de la documentación provista por la supervisión de TI de la UAI del organismo, se constató que no se realizaron auditorías internas de TI sobre el SIGADE; este escenario evidencia la falta de un efectivo control interno sobre los procesos y procedimientos llevados a cabo por la DGTIC para la prestación de los servicios de TI brindados por los proveedores internos y externos.



Auditoría General de la Nación

En función de lo establecido en la Res. 48/05²¹ (SIGEN, Art. 13 - Auditoría Interna de Sistemas), las unidades de auditoría interna definidas en la Ley N° 24.156, deben, entre otras cuestiones, contemplar la ejecución de auditorías de sistemas para efectuar revisiones objetivas de los controles informáticos y preparar informes sobre sus hallazgos y recomendaciones. Adicionalmente, las buenas prácticas referidas al control de TI (CobIT v4.1 - ME2.1: Monitorización del Marco de Trabajo de Control Interno y ME2.2: Revisiones de Auditoría) establecen que se debe monitorear de forma continua, comparar y mejorar el ambiente de control de TI y el marco de trabajo de control de TI para satisfacer los objetivos organizacionales, y se debe evaluar la eficiencia y efectividad de los controles internos de revisión de la gerencia de TI.

La falta de un adecuado ambiente de control interno de TI obre el SIGADE expone a la DADP a riesgos no detectados y, por lo tanto, no mitigados.

4.2. Seguridad de la Información

4.2.1. *El organismo no cuenta con un Comité de Seguridad de la Información y tampoco con una estructura organizacional adecuada para atender y gestionar las políticas y procedimientos de seguridad de la información aplicables transversalmente a toda la organización. Esta situación impacta sobre el adecuado cumplimiento de los principios de confidencialidad, integridad y disponibilidad de la información organizacional.*

Luego de evaluada la documentación técnica provista por el organismo y de las entrevistas mantenidas con la DGTIC y con Secretaría Legal y Administrativa del Ministerio de Economía, se constató que el 6 de marzo de 2021 el Ministerio de Economía aprobó su “Política de Seguridad de la Información” (Resol. N° 99/2021, código SI-POL-01, versión 1.2), y se designó a la titular de la Secretaría Legal y Administrativa del Ministerio como

²¹ Dejada sin efecto por la Res. 87/22 luego de finalizar las tareas de campo, la que mantiene lo indicado en su art. 12.



Auditoría General de la Nación

Responsable de Seguridad de la Información del organismo²². Esto evidencia que durante el período auditado el organismo no constituyó un Comité de Seguridad de la Información que diseñe e implemente un Plan de Seguridad de la Información que abarque a todo el organismo, que dicte y formalice las políticas y procedimientos de Seguridad de la Información, y que defina y establezca una estructura organizacional especializada que se encargue de la ejecución operativa del plan y del cumplimiento de las políticas y procedimientos pertinentes.

En función de lo que establecen las buenas prácticas en la materia (ISO 27001 - Aspectos organizativos para la Seguridad de la Información; CobIT v4.1 - DS5.1: Administración de la Seguridad de TI y DS5.2: Plan de Seguridad de TI), toda organización debe administrar adecuadamente la Seguridad de la Información a partir de los siguientes aspectos: i) concientizar internamente a la organización sobre la necesidad de implementar y cumplir con políticas y procedimientos que garanticen la salvaguarda de los activos de información de la organización y del negocio; ii) conformar un Comité de Gestión de Seguridad de la Información que dicte, formalice, controle y actualice las políticas y procedimientos de Seguridad de la Información; iii) asignar una estructura técnica especializada contando con todos los medios, recursos e insumos técnicos necesarios, dependiente de las máximas autoridades de la organización, para que se responsabilice de la administración integral de la Seguridad de la Información.

Que el organismo no implemente y mantenga en el tiempo estas buenas prácticas vinculadas a la Seguridad de la Información a nivel organizacional pone en riesgo el cumplimiento de los principios de confidencialidad, integridad y disponibilidad de la información organizacional.

²² Los aspectos vinculados a la “Política de Seguridad de la Información” mencionada, por tratarse de un hecho posterior al período auditado, serán tenidos en cuenta en oportunidad de autorizarse futuros proyectos de auditoría.



Auditoría General de la Nación

4.2.2. Los niveles de acceso otorgados en el SIGADE a los usuarios de la DADP no se corresponden con las funciones según el perfil que poseen los agentes usuarios del sistema, lo que compromete la segregación de funciones y ponen en riesgo la integridad, disponibilidad y confidencialidad de la información.

Del análisis de la documentación remitida por el auditado, y de las reuniones mantenidas con personal técnico de la DGTIC y con usuarios de distintos niveles jerárquicos de la DADP, se constató que todos los usuarios con cuentas de usuario activas en el SIGADE poseen, dentro del sistema, el mismo perfil y las mismas funciones a través del rol “Operador”, lo que permite a todos estos usuarios un acceso transversal a las funcionalidades y a la información registrada en el sistema, sin contemplar la función, responsabilidades o área a la que pertenezca cada uno de estos usuarios.

Este escenario no garantiza una adecuada separación por funciones dentro del SIGADE; además, la configuración de acceso de usuarios aplicada al momento de esta auditoría no permite que por el sistema se pueda controlar que un usuario perteneciente a una coordinación no acceda sin autorización, a información de otra coordinación. Cabe aclarar que el SIGADE, a través de la configuración de usuarios, permite acotar las funcionalidades específicas para cada uno de ellos, pero estas restricciones no se aplican por decisión directiva. Por último, se verificó que el sistema no posee alertas de operaciones que permitan el control de las actividades ejecutadas por los usuarios.

Las buenas prácticas en gestión de usuarios (CobIT v4.1 - DS 5.4: Administración de cuentas de usuario, PO 7.3: Asignación de roles, PO 7.8: Cambios y terminación de trabajo; ISO 27002 - 11.2.1 Registro de usuarios, 11.2.2 Gestión de privilegios, 10.1.3 Segregación de funciones) establecen que se debe verificar que el nivel de acceso otorgado se corresponda con los perfiles y las funciones establecidas para cada perfil y que sea consistente con la política de seguridad de la información del organismo, entre otras: i) que no se comprometa la separación de las tareas o segregación de funciones, ii) que se asignen los privilegios a los individuos sobre las bases de necesidad de uso en función de sus



Auditoría General de la Nación

responsabilidades y funciones para cada proceso de negocio, y iii) las funciones y las áreas de responsabilidad se deben encontrar segregadas para reducir las oportunidades de modificaciones sin autorización o no intencionales.

Al no estar establecidas sistemáticamente la separación de funciones y el control de acceso a los datos entre áreas, la situación observada pone en riesgo los objetivos de garantizar la confidencialidad, integridad y disponibilidad de la información del SIGADE y de reducir las oportunidades de modificaciones sin autorización o no intencionales.

4.2.3. *La DGTIC no realiza pruebas de seguridad sobre el SIGADE y los sistemas relacionados, lo que no permite medir el grado de seguridad en que se encuentran estos entornos, diagnosticar y tomar acciones correctivas que minimicen los riesgos que pudieran comprometer la confidencialidad, integridad y disponibilidad de la información.*

Del análisis de la documentación técnica entregada y de las entrevistas mantenidas con personal de la DGTIC, se constató que los procedimientos de pruebas y análisis de seguridad informática aplicados no incluyen a las aplicaciones críticas del organismo, entre ellas al SIGADE y a los sistemas relacionados.

Las buenas prácticas en seguridad de los sistemas señalan que la necesidad de mantener la integridad de la información y de proteger los activos de TI, requiere de un proceso de administración de la seguridad. Este proceso incluye, entre otros, realizar pruebas periódicas así como realizar acciones correctivas sobre las debilidades o incidentes de seguridad identificados. Una efectiva administración de la seguridad protege todos los activos de TI para minimizar el impacto en el negocio causado por vulnerabilidades o incidentes de seguridad (CobIT v4.1 - DS5: Garantizar la seguridad de los sistemas)

La falta de pruebas de seguridad informática sobre el SIGADE y su entorno generan las siguientes limitaciones: i) no permite medir, en materia de seguridad, el grado de solidez del sistema; ii) podrían no detectarse vulnerabilidades que puedan comprometer la



Auditoría General de la Nación

confidencialidad, integridad y disponibilidad de la información; y iii) posibles fallas en las acciones correctivas para minimizar el impacto de las vulnerabilidades o incidentes de seguridad.

4.2.4. Los procedimientos aplicados por la DGTIC para la administración, evaluación y monitoreo continuo sobre las tablas de auditoría generadas por las transacciones del SIGADE, ponen en riesgo la prevención y la detección temprana de anomalías en la ejecución de transacciones y de actividades no autorizadas de procesamiento de información que pueden afectar la integridad de los datos del SIGADE.

De la evaluación de la información remitida y de las entrevistas mantenidas con las áreas usuarias de la DADP y con los administradores del SIGADE, esta auditoría detectó los siguientes desvíos sobre la gestión de las pistas de auditoría del SIGADE: i) no se cuenta con documentación del análisis y la designación de las tablas del sistema que se consideraban críticas, a fin de justificar cuáles de ellas deben ser auditadas, y que a su vez, permita generar procedimientos que dicten cuáles serán los criterios para su control y revisión; ii) las tablas de auditoría no se revisan de manera periódica, a fin de detectar de manera temprana movimientos transaccionales inadecuados, tanto a través del sistema como de intervenciones manuales a la base de datos, solo se examinan cuando existe un requerimiento específico de revisión; iii) no se están auditando las modificaciones realizadas por los administradores de la base de datos sobre la tabla de amortizaciones, a la vez que tampoco se registra el usuario que realiza movimientos sobre ella; iv) resulta dificultoso llevar la trazabilidad que permita vincular los registros de las tablas de auditoría del sistema con los tickets de la Mesa de Servicios que justificaron las operaciones realizadas por los administradores, a demanda de los usuarios superiores de la DADP, en las intervenciones manuales sobre la base de datos; v) con la información registrada en las tablas de auditoría no es posible evaluar qué información fue modificada, pues en estas tablas solo se graba el registro final modificado (después del evento) no así el registro original que fuera modificado (antes del evento); en consecuencia, con la información que brindan las tablas de auditoría, no es posible determinar qué información del registro fue



Auditoría General de la Nación

modificada; y vi) las tablas de auditoría son accesibles a los administradores de la base de datos y no se auditan los movimientos que éstos pudieran realizar sobre ellas.

En relación a lo expuesto, las buenas prácticas sobre el seguimiento y control en la gestión de operaciones, establecen que: i) para detectar las actividades no autorizadas de procesamiento de información es recomendable que los sistemas se monitoreen y controlen para asegurar que los usuarios realicen solamente las actividades para las cuales fueron autorizados explícitamente (ISO 27002 - 10.10 Seguimiento y control); ii) se produzcan y mantengan pistas de auditoría en las cuales se registren las actividades, excepciones y eventos de seguridad de la información de los usuarios, por un período acordado para ayudar en futuras investigaciones y en el seguimiento del control de acceso. En todos los sistemas, sean automatizados o no, las pistas de auditoría deben estar siempre presentes, y deben cumplir el requisito básico de que cualquier transacción generada automáticamente, pueda ser rastreada hasta el evento o condición que la generó (ISO 27002 - 10.10.1 Registro de auditoría); iii) que la información de registro esté protegida contra la manipulación y procesos no autorizados (ISO 27002 - 10.10.3 Protección de la información de los registros de actividad); y iv) realizar una efectiva administración de la seguridad protege todos los activos de TI para minimizar el impacto en la organización causado por vulnerabilidades o incidentes de seguridad (CobIT v4.1 - DS5: Garantizar la seguridad de los sistemas).

Por último, las buenas prácticas sobre arquitectura de la información establecen que se debe desarrollar un diccionario corporativo de datos que contenga, entre otras cosas, el esquema de clasificación de datos y los niveles de seguridad, para mejorar la calidad de la toma de decisiones gerenciales asegurando que se proporciona información confiable y segura. Este proceso de TI también es necesario para incrementar la responsabilidad sobre la integridad y seguridad de los datos y para mejorar la efectividad y control de la información compartida a lo largo de las aplicaciones y de las entidades (CobIT v4.1 - PO2: Definir la arquitectura de la información).



Auditoría General de la Nación

La desatención de las buenas prácticas antes mencionadas, puede: i) impactar en la detección oportuna de posibles cambios indebidos a los datos del sistema; ii) comprometer la integridad de la información; iii) dar lugar a la posibilidad de que existan datos inconsistentes; iv) dar lugar a ineficientes controles de aplicación; y v) dificultar la compartición de datos entre aplicaciones, sistemas y entidades. Concurrentemente, se pone en riesgo el cumplimiento de la política de seguridad del organismo, la gestión de incidentes, las mejoras de la seguridad de la información y el cumplimiento de regulaciones internas y externas.

Asimismo, la información de auditoría necesita ser protegida debido a que, si los datos son modificados o borrados, su existencia puede crear una falsa sensación de seguridad.

4.3. Continuidad de las Operaciones Organizacionales

4.3.1. *La DGTIC no ha incorporado a las aplicaciones críticas de la organización, entre ellas al SIGADE, dentro del Plan de Recuperación ante Desastres oficialmente vigente dentro del período auditado. Este escenario implica un riesgo crítico y de alto impacto sobre la disponibilidad de los sistemas de información críticos del organismo ante una interrupción de los servicios de TI, sobre los cuales todas las áreas operativas tienen una alta dependencia.*

A partir del análisis efectuado sobre la documentación provista por la DGTIC, y de las entrevistas mantenidas con el Director de la DGTIC y con el Director de Explotación de la DGTIC, se constata que el Plan de Recuperación ante Desastres vigente en el organismo al momento de esta auditoría no incluye a los sistemas de información críticos del organismo, entre ellos al SIGADE, objeto de esta auditoría.

En función de lo que establecen las buenas prácticas en la materia (ISO 22.301 - Directrices para garantizar la Continuidad del Negocio; ISO 24.762 - Directrices para asegurar la continuidad de los servicios de TI; ISO 27.001 - Sistemas de gestión de la seguridad de la



Auditoría General de la Nación

información; CobIT v4.1 - DS4: Garantizar la continuidad del servicio), un Plan de Recuperación ante Desastres (DRP, por sus siglas en inglés) es un proceso de restitución que cubre los datos, el hardware y el software crítico, para que un negocio pueda comenzar de nuevo sus operaciones en caso de ocurrencia de un desastre natural, errores humanos, ciberataques o ataques causados por terceros de cualquier tipo, que atenten contra la continuidad del funcionamiento de la organización. En este proceso no solo intervienen las áreas técnicas responsables de su ejecución sino también las áreas críticas de la organización, incluida la alta dirección, que deben formar parte de un comité de crisis para actuar al momento de su activación.

Conforme las mejores prácticas anteriormente indicadas, un Plan de Recuperación ante Desastres debe contener, desarrollar y ejecutar como mínimo los siguientes pasos:

- a) desarrollar una política de continuidad del negocio,
- b) realizar una evaluación de riesgos,
- c) realizar un análisis de impacto al negocio,
- d) desarrollar estrategias de recuperación y continuidad del negocio,
- e) concientizar, capacitar y probar los planes,
- f) mantener y mejorar el plan de recuperación ante desastres.

Si bien se pudo verificar que la DGTIC cuenta con un DRP y un plan de pruebas elaborado y ejecutado de acuerdo al marco metodológico que indican las buenas prácticas en la materia, en caso de que se requiera activarlo, este plan resulta incompleto e insuficiente para asegurar la disponibilidad de la información crítica del organismo debido a que el DRP vigente al momento de esta auditoría no contempla un aspecto central: garantizar la disponibilidad del software crítico de la organización.

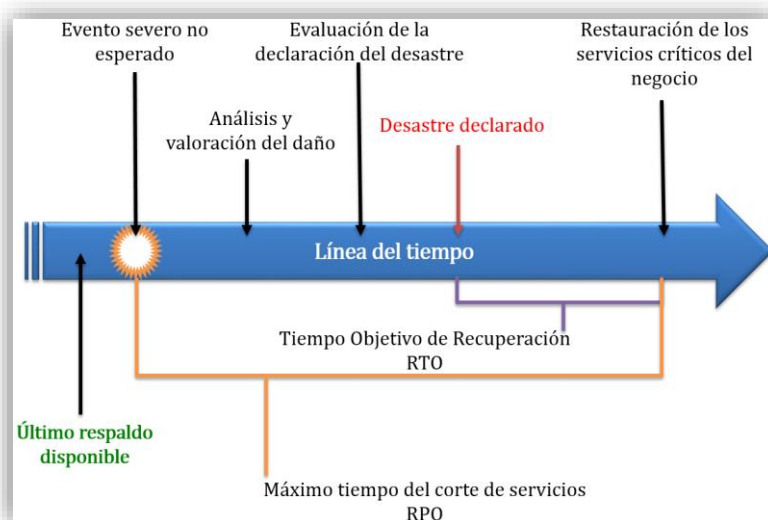
Abarcar este plan adecuadamente ofrece la ventaja de responder de forma planeada y proactiva ante una catástrofe y minimizar su impacto en los objetivos y misión de la



Auditoría General de la Nación

organización y sobre los sistemas de información que constituyen el soporte informático a los servicios que ésta presta.

Ilustración N° 3 – Etapas de un DRP:



Fuente: elaboración propia en base a ISO 24.762

Que la DGTIC, a cargo de la gestión y administración de la infraestructura tecnológica de los sistemas de información del organismo, no contemple a los sistemas de información críticos, entre los cuales se encuentra el SIGADE –objeto de esta auditoría– dentro de su Plan de Recuperación ante Desastres acorde a lo que establecen las buenas prácticas y su correspondiente plan de pruebas, documentación de simulacros y ajustes continuos, pone en riesgo la disponibilidad de las aplicaciones y de la información que dan soporte a los procesos operativos que son relevantes para la organización, incluidos a los ejecutados por la DADP.

4.3.2. *La DGTIC no ha incorporado, en sus políticas y procedimientos de resguardo, procesos de control que garanticen la identificación y el resguardo exitoso de los documentos (planillas de cálculo y otros documentos electrónicos) que son considerados clave para los procesos de seguimiento y control de los instrumentos de deuda registrados*



Auditoría General de la Nación

en el SIGADE, lo que pone en riesgo la disponibilidad de la información utilizada por la DADP en sus procesos operacionales diarios.

En función del análisis de la documentación técnica provista por la DGTIC y de las entrevistas mantenidas con personal técnico de la Dirección de Explotación de la DGTIC y con personal operativo de las distintas coordinaciones de la DADP, se constató que, si bien se realizan las copias de resguardo sobre las carpetas compartidas de la DADP alojadas en los servidores de archivos, las políticas y procedimientos de *back-ups* aplicados por la DGTIC carecen de procedimientos de identificación y de control de resguardo sobre los documentos administrados y almacenados por los usuarios de la DADP en las carpetas compartidas asignadas. Según el Manual de Procesos (Disposición N°1/2015, emitido por el ex Ministerio de Economía y Finanzas Públicas, actual Ministerio de Economía) estos documentos son esenciales para los procesos de seguimiento y control de los instrumentos de deuda registrados en el SIGADE.

Las buenas prácticas sobre políticas y procedimientos de *back-ups* y pruebas de restauración establecen que se debe garantizar la posesión de copias de resguardo de toda la información crítica utilizada por la organización, relevando de manera continua las necesidades de resguardo de información con las áreas usuarias. Además, se debe someter a la solución de *back-up* y recuperación de datos a pruebas formalizadas en forma periódica con la debida documentación de los resultados obtenidos en ellas, con la aceptación y control de las áreas usuarias. Estos testeos deben poner a prueba el funcionamiento de la tecnología utilizada, y es la forma más adecuada de detectar y resolver posibles fallos antes de que ocurra un incidente real (ISO 27.001 - Aspectos de seguridad - Información para la gestión de continuidad de negocio y CobIT v4.1 - DS4: Garantizar la continuidad del servicio).

Aplicar procedimientos de *back-up* que no garanticen la identificación y el resguardo exitoso de la totalidad de los documentos críticos que la DADP almacena en las carpetas



Auditoría General de la Nación

compartidas, pone en riesgo la disponibilidad de dicha información ante un incidente que requiera aplicar una restauración.

4.4. Operaciones de TI

4.4.1. *El Manual de Procesos utilizado por la DADP como guía para la ejecución de los procesos operativos de registración, seguimiento y control de los instrumentos de deuda se encuentra desactualizado, lo que conlleva el riesgo de que los agentes intervinientes en la ejecución diaria de los procedimientos de registración, seguimiento y control de los instrumentos de deuda apliquen acciones atemporales.*

Del análisis de la documentación técnica provista por la DADP (Manual de Procesos, mapa de procesos ejecutados, herramientas ofimáticas utilizadas y de los sistemas de información intervinientes) y de las entrevistas mantenidas con la DADP, con las distintas coordinaciones y usuarios de la DADP, se verificó que el Manual de Procesos formalizado a través de la Disposición N° 1/2015 no ha sufrido modificaciones desde su aprobación, lo que implica que todos los usuarios de distintos perfiles y funciones de la DADP estén utilizando un manual para la ejecución de los procesos de registración, seguimiento y control de los instrumentos de deuda que se encuentra desactualizado y que no contempla nuevos procesos, aplicaciones y documentos ofimáticos que se fueron incorporando desde la aprobación del manual hasta la fecha del fin del período auditado.

Las buenas prácticas orientadas a procedimientos e instrucciones de administración de procesos de negocio indican que se deben definir, implementar y mantener procedimientos estándar para operaciones y garantizar que el personal operativo está familiarizado con todas las tareas de operación relativas a ellos (CobIT v4.1 - DS13.1: Procedimientos e Instrucciones de Operación). La gestión de procesos de negocio (BPM, por sus siglas en inglés), en el apartado “Mejora de Procesos”, establece que todos los procesos de negocio se degradan, se transforman o cambian con el tiempo debido a que surgen nuevas necesidades empresariales, nuevas tecnologías o nuevas reglas establecidas por el contexto.



Auditoría General de la Nación

Para afrontar estas variaciones dinámicas sobre los procesos de negocio es importante que la organización implemente prácticas metodológicas, con inversión en tiempo y en recursos dedicados, para garantizar la mejora y actualización continua de los procesos clave del negocio.

La falta de prácticas de mantenimiento y actualización continua del Manual de Procesos —considerado una guía clave para la DADP en la ejecución diaria de los procedimientos de registración, seguimiento y control de los instrumentos de deuda—, puede generar acciones erróneas por su atemporalidad por parte de los agentes intervinientes en cuestiones operativas y en la toma de decisiones de los responsables jerárquicos de las distintas coordinaciones de la DADP, al guiarse de procesos desactualizados.

4.5. Adquisiciones y contratación de TI

4.5.1. *No se encuentran formalizados los acuerdos de niveles de servicio entre el organismo y la UNCTAD, proveedor del servicio de soporte y mantenimiento continuo del SIGADE, por lo que resulta dificultoso que la DADP y la DGTIC puedan gestionar y controlar adecuadamente la calidad de servicio sobre las acciones correctivas, adaptativas y evolutivas que ejecuta el proveedor en el SIGADE.*

A partir de la evaluación de la información técnica provista por la DADP y de las entrevistas mantenidas con la DADP y con las áreas técnicas de la DGTIC que brindan soporte sobre el SIGADE, se constató que el organismo no cuenta con acuerdos de niveles de servicio de soporte y mantenimiento continuo del SIGADE formalizados con la UNCTAD.

Si bien las condiciones generales del servicio de soporte provisto se cumplen con razonabilidad, no se encuentran documentados y formalizados los acuerdos de niveles de servicios con la UNCTAD en referencia al soporte sobre el SIGADE, que permitan garantizar respuesta técnica y funcional, en tiempo y forma, del proveedor del servicio a la



Auditoría General de la Nación

demanda de disponibilidad requerida por los procesos operativos de gestión de la deuda pública, en especial sobre aquellos que se aplican específicamente en nuestro país (localizaciones funcionales).

Las buenas prácticas en gestión de proveedores de TI establecen que se debe definir y actualizar de manera continua un marco de trabajo que brinde un proceso formal de administración de niveles de servicio entre el cliente y el prestador de servicio. El marco de trabajo mantiene una alineación continua con los requerimientos y las prioridades del negocio y facilita el entendimiento común entre el cliente y el(los) prestador(es) de servicio. El marco de trabajo incluye procesos para la creación de requerimientos de servicio, definiciones de servicio, acuerdos de niveles de servicio, acuerdos de niveles de operación y las fuentes de financiamiento. Estos atributos están organizados en un catálogo de servicios. El marco de trabajo define la estructura organizacional para la administración del nivel de servicio, incluyendo los roles, tareas y responsabilidades de los proveedores externos e internos y de los clientes (CobIT v4.1 - DS1.1: Marco de trabajo de la administración de los niveles de servicio, ITIL - capítulo “Gestión del Nivel de Servicio”).

La carencia de un compromiso plasmado en un acuerdo de niveles de servicio debidamente actualizado impide al organismo tener garantías de la calidad y, principalmente, la medición de los alcances pactados del servicio en aspectos tales como tiempo de respuesta, disponibilidad horaria, documentación disponible, personal asignado al servicio, respuesta a nuevos requerimientos funcionales sobre el sistema, etc., lo que indefectiblemente conduce a una administración informal de la disponibilidad del SIGADE y de sus condiciones frente a los requerimientos críticos por parte de la DADP como principal área usuaria del sistema.

4.6. Sistemas de información

4.6.1. *El uso de planillas de cálculo para el control de la información que se registra en el SIGADE durante el ciclo de vida de los instrumentos de deuda pública, no garantiza la*



Auditoría General de la Nación

separación de funciones en el control cruzado, ni la integridad, confidencialidad y la disponibilidad de la información que estas planillas contienen. La falta de aplicaciones que den soporte automatizado a los procesos operativos de la DADP pone en riesgo la eficiencia en el logro de los objetivos establecidos en el Manual de Procesos para la registración, el seguimiento y control de los instrumentos de deuda pública.

En base a los relevamientos realizados con usuarios del SIGADE de distintos niveles jerárquicos, y al análisis de los documentos técnicos provistos por la DADP, entre otros, el Manual de Procesos (Disposición N° 1/2015), se verificó que la DADP utiliza a diario un catálogo de planillas de cálculo, almacenadas y administradas en carpetas compartidas – alojadas en servidores de red corporativos– por cada coordinación. Entre otros, la información generada por estas planillas se utiliza para llevar a cabo actividades de seguimiento y controles –pre y pos registro– sobre la información ingresada en el SIGADE durante todo el ciclo de vida de los instrumentos de deuda pública, y para conciliar y corregir/ajustar la información de salida generada por el SIGADE.

A partir del análisis de este escenario, esta auditoría constató que: i) dentro de cada coordinación, todos los usuarios tienen acceso de lectura y escritura sobre todas las planillas allí almacenadas. Esta situación refleja ineficiencia en la segregación de acceso a la información según los perfiles y las funciones de cada perfil; ii) el método aplicado por la DADP para el control y seguimiento sobre las intervenciones de los usuarios a la información contenida en las planillas de cálculo, y con el objetivo de establecer una trazabilidad de las operaciones ejecutadas por aquellos, es que cada usuario “firma” escribiendo sus iniciales en una celda, toda vez que efectúe un cambio sobre la información contenida en las planillas. Este método es insuficiente, ineficiente y vulnerable, en consecuencia, su aplicación no brinda garantías sobre la integridad de la información; iii) la información contenida en estas planillas, en determinadas circunstancias operativas, es utilizada por la DADP como dato empírico para petitionar intervenciones manuales a la base de datos del SIGADE a fin de corregir/ajustar las inconsistencias que no puedan corregirse a través del sistema –ejemplo: ajustes de diferencias generadas por la cantidad



Auditoría General de la Nación

acotada de decimales que ofrece el SIGADE a nivel usuario, respecto de la cantidad de decimales que requieren algunos instrumentos de deuda–; iv) según lo indicado en el Manual de Procesos de la DADP y por la ponderación operativa señalada por los usuarios de esta dirección, la información que contienen las planillas de cálculo es relevante y esencial para la ejecución de los procesos administrativos de la DADP. No obstante, y en consonancia con lo indicado en el hallazgo 4.1.1., la DGTIC no ha realizado un relevamiento de requerimientos tecnológicos y funcionales en la DADP, a fin de reemplazar este catálogo de planillas de cálculo por un aplicativo o por una herramienta provista por el propio SIGADE que permita realizar los controles y seguimientos –pre y pos registro– de la información imputada en el sistema, subsanando las debilidades y limitaciones de confidencialidad, integridad y disponibilidad que presentan las planillas de cálculos; y v) del análisis del manual de usuarios del SIGADE, esta auditoría pudo verificar que la versión 6 del sistema –en producción al momento de esta auditoría– cuenta con herramientas que permiten adjuntar archivos de trabajo de cualquier formato (Word, Excel o PDF, entre otros) a un instrumento de deuda pública registrado en la base de datos. Se trata de una funcionalidad que ofrece la posibilidad de almacenar todos los documentos contractuales de un acuerdo de préstamo o de un título de deuda para referencias o consultas rápidas por parte de los agentes de la DADP. Dicha funcionalidad no es utilizada por los usuarios del sistema.

Las buenas prácticas en adquisición e implantación de aplicativos establecen que se deben identificar los requerimientos funcionales y de control del negocio a fin de traducirlos en soluciones automatizadas efectivas y eficientes, que satisfagan los requerimientos del usuario y consideren los requerimientos de seguridad y control desde el principio, aprovechando la inversión en tecnología existente (CobIT v4.1 – AI: Adquisición e implantación).

Asimismo, las buenas prácticas en adquisición y mantención de software aplicativo establecen, entre otras cuestiones, que las aplicaciones deben estar disponibles de acuerdo con los requerimientos del negocio, y que este proceso debe cubrir el diseño de las



Auditoría General de la Nación

aplicaciones, la inclusión apropiada de controles aplicativos y requerimientos de seguridad (CobIT v4.1 – AI2: Adquirir y mantener software aplicativo).

En cuanto a facilitar la operación y el uso de los aplicativos, las buenas prácticas establecen que el conocimiento sobre los sistemas debe estar disponible y que este proceso requiere la generación de documentación y manuales para usuarios y para TI, así como se debe proporcionar entrenamiento para garantizar el uso y la operación correctos de las aplicaciones (CobIT v4.1 – AI4: Facilitar la operación y el uso).

Las planillas de cálculo, herramientas clave para el control interno de la DADP, no cuentan con la seguridad necesaria para garantizar la separación de funciones en el control cruzado, la integridad de la información que contienen (datos y fórmulas de cálculo), la confidencialidad y la disponibilidad de la información de control interno.

La falta de un relevamiento por parte de la DGTIC en conjunto con la DADP respecto a las necesidades técnicas y funcionales para reemplazar las planillas de cálculo dificulta que la organización apoye su operatividad de manera adecuada y segura con aplicaciones automatizadas que faciliten el logro de los objetivos operacionales de la DADP, considerando siempre la premisa de integridad, confidencialidad y disponibilidad de la información garantizando su eficiente control interno y cruzado.

4.6.2. *Se ejecutan procedimientos de rectificaciones de datos de instrumentos de deuda pública por fuera del SIGADE, lo que no brinda garantías sobre la integridad de la información y conlleva el riesgo inherente de modificaciones no autorizadas, malintencionadas o erróneas sobre la base de datos del SIGADE.*

Del análisis de la información recibida y de las entrevistas mantenidas con los administradores del SIGADE, esta auditoría constató que: i) los administradores del sistema llevan a cabo rectificaciones de datos en la base de datos del SIGADE por fuera



Auditoría General de la Nación

del sistema –utilizando sentencias SQL²³– a pedido de los usuarios de la DADP por medio de la Mesa de Servicios; ii) para efectuar las rectificaciones de datos, los administradores del sistema se registran con un usuario administrador genérico, lo que no permite identificar al autor de estas operaciones; iii) no existe un documento formal que establezca los procedimientos oficiales a aplicar para efectuar intervenciones manuales a la base de datos del SIGADE por solicitud de los usuarios; y iv) no es posible obtener la trazabilidad de las rectificaciones de datos realizadas por los administradores del sistema ya que no hay información en las tablas de auditoría que permita vincular cada transacción de intervención manual con el ticket de la Mesa de Servicios que contiene la petición del usuario que la originó.

A continuación, se detallan algunos ejemplos de solicitudes de intervenciones manuales a la base de datos del SIGADE²⁴: i) usuario solicita inserción de varios registros de patrones, por lo cual se deben generar los *scripts*²⁵ de los *inserts*²⁶ y su posterior ejecución, en la base de datos SIGADE producción; ii) usuario solicita la eliminación del SIGADE Nro. xxx, borrarlo en todas las tablas donde impacta ese número de SIGADE; iii) usuario solicita la modificación de los montos de 5.287 patrones para el SIGADE Nro. xxx. Preparación de los *scripts* para el impacto de esos cambios y ejecución de los scripts en la base de datos SIGADE de producción; iv) usuario solicita la creación de un script para insertar un patrón irregular de principal (tanto en el patrón irregular como en la tabla de amortización) del SIGADE Nro. xxx, tramo xx con fecha xx.xx.xxxx y monto xx.xxx.xxx).

²³ La sigla que se conoce como SQL corresponde a la expresión inglesa *Structured Query Language*, entendida en español como Lenguaje de Consulta Estructurado, la cual identifica a un tipo de lenguaje vinculado con la gestión de bases de datos de carácter relacional que permite la especificación de distintas clases de operaciones entre éstas.

²⁴ Se reemplazan los nombres de los solicitantes por “usuario” y los números identificatorios de los instrumentos de deuda con “x” para preservar la confidencialidad de la información.

²⁵ En informática, se denomina “*SCRIPT*” a una serie de comandos/instrucciones de programación que se almacenan dentro de un archivo de texto y los cuales se caracterizan por presentar un tamaño muy pequeño, que además de ello suelen ejecutarse en grupos por medio de un intérprete en tiempo real.

²⁶ En informática, “*INSERT*” es una instrucción que se utiliza para añadir datos a una tabla de una base de datos.



Auditoría General de la Nación

Según las buenas prácticas en administración de bases de datos, el concepto de separación de funciones dicta que las tareas de administración deben ser divididas entre varios usuarios y no entre un sólo individuo con privilegios ilimitados. Asimismo, la división de tareas como administración, seguridad y operaciones hace que sea menos probable que los usuarios abusen de sus privilegios y también reduce aún más la superficie de ataque de cuentas comprometidas. La función del DBA²⁷ es la de proteger los datos, y no de procesarlos. El DBA no es un usuario del sistema, en consecuencia, no administra valores de datos sino la actividad de ellos (CobIT v4.1 - PO4.11: Segregación de funciones).

Por otro lado, las buenas prácticas en seguridad de la información establecen que los administradores no deben utilizar cuentas genéricas o compartidas y las actividades de los DBA con privilegios excesivos deben ser supervisadas de cerca. Además, se debe prestar consideración para establecer los roles de acceso de usuarios basados en los requerimientos de la actividad que desempeñan, así como es necesario el uso de procedimientos de seguimiento y control para asegurar que los usuarios realicen solamente las actividades para las cuales han sido explícitamente autorizados (CobIT v4.1 - PO4.10: Supervisión, ISO 27002 - 11.6.1 Restricción de acceso a la información).

De igual manera, las buenas prácticas en administración de identidad establecen que todos los tipos de usuarios (operadores, usuarios de sistema y administradores de bases de datos) y su actividad en el sistema deben ser identificables de manera única para trazar las actividades del individuo responsable (CobIT v4.1 - DS5.3: Administración de identidad).

Por último, las buenas prácticas en gestión de operaciones recomiendan que los procedimientos operativos se documenten, se mantengan y se encuentren disponibles para todos los usuarios que los necesiten, y que además se traten como documentos formales y

²⁷ DBA o Administrador de base de datos, por sus siglas en inglés, es un profesional de TI certificado como responsable de gestionar los aspectos técnicos, tecnológicos, científicos, de inteligencia de negocios, de seguridad, legales de bases de datos, y de la calidad de datos de las bases de datos de los sistemas de información de una organización.



Auditoría General de la Nación

los cambios sean autorizados por la alta dirección (ISO 27002 - 10.1.1 Documentación de los procedimientos administrativos).

El no cumplimiento de las buenas prácticas señaladas puede dar lugar a cambios no autorizados, malintencionados o a errores involuntarios en los datos, poniendo en riesgo la integridad y consistencia de los datos almacenados en la base de datos del SIGADE.

Asimismo, las cuentas compartidas y/o genéricas eliminan la responsabilidad, aumentan el riesgo y hacen que la auditoría de la actividad del/los administrador/es sea esencialmente imposible de seguir y/o controlar. El uso inadecuado de los privilegios de administración del sistema puede ser el factor más importante que contribuya a fallas o brechas de los sistemas.

Concurrentemente, la situación observada provoca: i) que no se ejecuten de manera efectiva y eficiente las responsabilidades y los roles clave de TI, y un control inapropiado de dichas funciones; ii) un mal funcionamiento de los procesos de TI; y iii) que la administración de accesos no cumpla los requerimientos de confidencialidad, integridad y disponibilidad de la información del sistema, lo que puede causar una inadecuada investigación de actividades de acceso inapropiadas y una inadecuada protección de los activos de información.

5. ANÁLISIS DE LA VISTA

Por nota N° 13/2022-AG03 (con fecha 21 de abril de 2022) la AGN remite el día 26 de abril de 2022 el proyecto de informe de auditoría sujeto a discusión sobre “Sistema de Gestión y Análisis de la Deuda (SIGADE) y sistemas relacionados” al Ministerio de Economía (MECON), otorgándole como tiempo máximo de respuesta un plazo de 15 (quince) días hábiles de recibida la presente nota.



Auditoría General de la Nación

A través de la nota N° NO-2022-49437391-APN-DGGDTYAI#MEC (reproducida en el Anexo I), el 17 de mayo de 2022, el MECON remite las respuestas propiciadas por la Dirección General de Tecnologías de la Información y Comunicaciones (DGTIyC), la Dirección de Administración de la Deuda Pública (DADP) y la Unidad de Auditoría Interna (UAI) a los hallazgos formulados en el mencionado proyecto de informe, contenidas en las siguientes notas anexas: IF-2022-46458559-APN-DGTIYC#MEC, IF-2022-46472001-APN-DGTIYC#MEC, IF-2022-47711131-APN-DADP#MEC y NO-2022-49324711-APN-UAI#MEC (también reproducidas en el Anexo I). Las respuestas del auditado no modifican los hallazgos.

Como Anexo II se incorpora el análisis efectuado en relación a la contestación de la vista del proyecto de informe por parte del auditado.

6. RECOMENDACIONES

La secuencia de las recomendaciones aquí expuestas sigue el mismo orden que los hallazgos del capítulo precedente.

6.1. Gobierno de TI

6.1.1. Implementar relevamientos con la comunidad usuaria vinculada con el SIGADE referidos a los procesos operativos ejecutados, las reglas de negocio y las necesidades funcionales y tecnológicas de los usuarios de las distintas coordinaciones integrantes de la DADP y de los niveles de satisfacción del servicio de TI. Desarrollar planes de acciones correctivas, evolutivas y adaptativas sobre el SIGADE a partir de los resultados obtenidos en estos relevamientos como parte de un plan de mejora continua.

6.1.2. Monitorear de forma continua el ambiente de control de TI y el marco de trabajo de control de TI sobre el SIGADE, evaluando la eficiencia y efectividad de los controles internos implementados por la DGTIC.



Auditoría General de la Nación

6.2. Seguridad de la información

6.2.1. Garantizar que el Comité de Seguridad de la Información se reúna periódicamente y dicte, revise, actualice e implemente las políticas y procedimientos que sean las más adecuadas a las necesidades del organismo en la materia.

6.2.2. Verificar que el nivel de acceso otorgado sea el adecuado al propósito del perfil y funciones que tiene cada usuario del SIGADE y que sea consistente con las políticas y procedimientos de seguridad de la información del organismo, garantizando el principio de segregación de funciones. Asignar los privilegios a los individuos sobre las bases de necesidad de uso y de evento por evento, en línea con la política de control de accesos, como el requerimiento mínimo para su rol funcional sólo cuando sea necesario. Las funciones y las áreas de responsabilidad se deben encontrar segregadas para reducir las oportunidades de modificaciones sin autorización o no intencionales.

6.2.3. Realizar evaluaciones de vulnerabilidad sobre los sistemas de información críticos del organismo, incluidos el SIGADE y los sistemas relacionados, de manera continua y ejecutando las acciones correctivas sobre las debilidades o incidentes de seguridad identificados. Garantizar que la implementación de la seguridad en TI sea probada y monitoreada de forma pro-activa y recurrente para mantener el nivel de seguridad requerido por la organización.

6.2.4. Diseñar e implementar un esquema de pistas de auditoría ponderando la criticidad y sensibilidad de la información del SIGADE que deba ser auditada. Implementar procedimientos de revisiones periódicas de las pistas de auditoría, alineados a las políticas de Seguridad de la Información del organismo, a fin de detectar de manera temprana movimientos transaccionales inadecuados, tanto a través del sistema como de intervenciones manuales a la base de datos del sistema. Arbitrar las medidas necesarias a fin de permitir la trazabilidad completa de las operaciones que se realizan sobre las tablas



Auditoría General de la Nación

auditadas, incluyendo campo modificado, dato original (antes y después del evento). Proteger las pistas de auditoría de manera que esta información no sufra agregaciones, cambios o eliminaciones sin ser auditadas, y llevar un registro sujeto a revisión periódica de las modificaciones que pudieran realizarse sobre dichas pistas (agregaciones, cambios o eliminaciones indebidas o por accidente).

6.3. Continuidad de las operaciones organizacionales

6.3.1. Desarrollar, probar y mantener en forma continua un Plan de Recuperación ante Desastres aprobado formalmente por un acto administrativo de la organización que incorpore a los sistemas de información críticos del organismo, entre ellos al SIGADE, siguiendo las directrices de las buenas prácticas al respecto, y que asegure la continuidad de los servicios y la disponibilidad de los sistemas de información de la organización.

6.3.2. Relevar periódicamente todos los activos de información utilizados por la DADP, documentarlos e incorporarlos a los procedimientos de *back-up* y pruebas de restauración.

6.4. Operaciones de TI

6.4.1. Implementar procedimientos de mantenimiento y actualización del Manual de Procesos (Disposición N° 1/2015) para su correcta aplicación por todos los usuarios de la DADP.

6.5. Adquisiciones y contratación de TI

6.5.1. Definir y actualizar de manera continua un marco de trabajo que brinde un proceso formal de administración de niveles de servicio entre el organismo como cliente y la UNCTAD como prestador del servicio de soporte y mantenimiento correctivo, adaptativo y evolutivo del SIGADE.



Auditoría General de la Nación

6.6. Sistemas de información

6.6.1. Relevar, desarrollar o adquirir e implementar aplicativos que reemplacen al catálogo de planillas de cálculo utilizadas por la DADP, que apoyen eficientemente a sus procesos operativos para el logro de los objetivos del área garantizando la integridad, confidencialidad, disponibilidad y autenticación de la información de seguimiento y control.

6.6.2. Tomar las medidas necesarias a fin de que las rectificaciones de datos de los instrumentos de deuda pública en el SIGADE no se realicen mediante intervenciones manuales de ningún tipo, que se garantice la integridad (salvaguardar la exactitud y totalidad de la información, así como los métodos de procesamiento) y consistencia de los datos almacenados, y la trazabilidad y auditabilidad de las operaciones rectificatorias. Que el reinicio y el reproceso estén soportados por el sistema, y que el proceso esté alineado con la arquitectura de seguridad de la información de la organización. Asimismo, la DGTIC debe implementar los procedimientos necesarios para garantizar que los administradores de sistemas y de las bases de datos se registren con su usuario personal, y no con usuarios genéricos de administración a fin de poder controlar y monitorear sus actividades.

7. CONCLUSIONES

El SIGADE es un software concebido como una herramienta para brindar soporte a la administración de la deuda externa e interna de los países. Tiene por objetivo principal satisfacer las necesidades operativas y analíticas de una oficina de gestión de la deuda pública, ya sea como *front office* (emisión de títulos de deuda), *middle office* (análisis) o *back office* (operaciones de registro y gestión).

En líneas generales, el sistema gestiona las obligaciones de deuda, como las contraídas o garantizadas por el Estado o las reasignadas, así como las donaciones y las reestructuraciones. También puede utilizarse para realizar el seguimiento de la deuda



Auditoría General de la Nación

externa privada sin garantía. Al momento de esta auditoría, el Programa de la UNCTAD, organismo proveedor del aplicativo, ha suministrado sus productos y servicios a 105 instituciones de 69 países.

En el ámbito del Ministerio de Economía, al momento de esta auditoría, el SIGADE se encuentra productivo en su versión 6 y presta servicios a un total de 49 usuarios que se distribuyen de la siguiente manera: 43 de la Oficina Nacional de Crédito Público (ONCP); 2 de auditoría interna; 1 de la Dirección General de Sistemas de Información de Administración Financiera (DGSIAF); 1 de Naciones Unidas (UNCTAD) y 2 del Congreso Nacional, en un entorno llamado “SIGADE imagen”.

El usuario principal del sistema es la ONCP, a través de la Dirección de Administración de la Deuda Pública (DADP), que tiene entre sus funciones:

- a) Participar en la formulación de los aspectos crediticios de la política financiera que, para el Sector Público Nacional, elabore el órgano coordinador de los sistemas de administración financiera.
- b) Organizar un sistema de información sobre el mercado de capitales de crédito.
- c) Tramitar las solicitudes de autorización para iniciar operaciones de crédito público.
- d) Mantener un registro actualizado sobre el endeudamiento público, debidamente integrado al sistema de contabilidad gubernamental.
- e) A través de los Reglamentos parciales N° 1 y N° 3 de la Ley 24.156 según Decretos 2662/92 y 1361/94, entre otras funciones, se le agrega a la ONCP, establecer un procedimiento mediante el cual los entes emisores y contratantes de deuda pública deberán comunicarle a la Oficina mencionada el o los desembolsos que realicen. Y a los fines de mantener actualizado el registro de las operaciones públicas deben todas las jurisdicciones y entidades del sector público nacional no financiero atender a los requerimientos de información relacionados con el mencionado registro en el plazo que establece el decreto, o en los que establezca la



Auditoría General de la Nación

ONCP. También prevé, que esta será quien dicte las normas específicas y mecanismos de uso obligatorio, relacionadas con el registro de la deuda pública directa y de aquella garantizada por la administración central acorde a los procedimientos que dicte la Contaduría General de la Nación, para su integración a los sistemas de contabilidad gubernamental y unidad de registro de crédito público, respectivamente, y dentro del marco del Sistema Integrado de Información Financiera. (Decreto 1344/07. Reglamento de la Ley 24.156).

A través del relevamiento y análisis efectuado sobre los procesos de Préstamos y Títulos Públicos, la auditoría se enfocó en seis ejes principales: 1) gobierno de TI, 2) seguridad de la información, 3) continuidad de las operaciones organizacionales, 4) operaciones de TI, 5) adquisiciones y contratación de TI, y 6) sistemas de información (entendiéndose como la evaluación de cuán adecuados son los controles con los que cuenta la aplicación, en cuanto a las interfaces de entrada, de salida, la integración, automatización, etc.); cuestiones que impactan sobre la confidencialidad, integridad y disponibilidad de la información brindada por el SIGADE.

Los principales hallazgos en el ámbito del gobierno de TI evidencian que la Dirección General de Tecnologías de la Información y las Comunicaciones (DGTIC) debe incluir al SIGADE dentro de su planificación estratégica y de control interno debido a que, entre otros, se ha detectado que no se ha realizado un relevamiento integral de activos, procesos, necesidades y satisfacción en el ámbito de la DADP; y no se cuenta con un adecuado ambiente de control interno que garantice la detección temprana de riesgos de TI y las acciones pertinentes para mitigarlos.

En cuanto a la seguridad de la información, la situación encontrada denota debilidades en la administración de los riesgos para garantizar la confidencialidad, integridad y disponibilidad de la información en niveles aceptables, pues se detectó que: i) no se cuenta con una estructura organizacional adecuada para atender y gestionar políticas y



Auditoría General de la Nación

procedimientos de seguridad de la información; ii) existe una ineficiente administración de accesos al sistema y a la base de datos; iii) no hubo pruebas de seguridad sobre el SIGADE y los sistemas relacionados; y iv) la administración de pistas de auditoría es ineficiente.

En relación a la continuidad de las operaciones organizacionales, el nivel de disponibilidad de los sistemas críticos no está alineado a las necesidades de la organización y a lo que establecen las buenas prácticas en esta cuestión, debido a que se halló que no se han incorporado a las aplicaciones críticas de la organización —entre ellas al SIGADE y sus aplicaciones relacionadas— dentro del Plan de Recuperación de Desastres, y no se ha incorporado en las políticas y procedimientos de resguardo procesos de control que garanticen la identificación y el resguardo con éxito de los documentos clave para los procesos de seguimiento y control de los instrumentos de deuda registrados en el sistema.

En cuanto a las operaciones de TI, se verificó que no se garantiza de manera apropiada el correcto funcionamiento de los procesos de registración y control sobre el ciclo de vida de los instrumentos de deuda, ya que se constató que el Manual de Procesos de la DADP se encuentra desactualizado.

Por otro lado, en adquisiciones y contratación de TI, existe un inadecuado control sobre el servicio brindado por el proveedor debido a que no se han formalizado los acuerdos de niveles de servicio entre el organismo y la UNCTAD.

Por último, en el ambiente de sistemas de información, se halló que: i) se utilizan planillas de cálculo para el seguimiento y control de la información que se registra en el sistema; ii) existe una falta de aplicaciones que den soporte automatizado a los procesos operativos de la DADP; y iii) se ejecutan procedimientos de rectificaciones de datos de instrumentos de deuda pública por fuera del sistema y con cuenta de usuario genérica. Este escenario evidencia que el SIGADE se encuentra perfilado como una herramienta informática específica de registración de los distintos instrumentos de deuda, los que se consolidan en el sistema a partir de imputaciones de datos que componen estos instrumentos en un



Auditoría General de la Nación

catálogo de planillas de cálculo y desde la ejecución de un conjunto de procedimientos de control sobre la información cargada en estas planillas. Este ambiente de administración y gestión de los distintos instrumentos de deuda se encuentra enmarcado y formalizado en el “Manual de Procesos” de la DADP.

En conclusión, en este contexto, resulta indispensable que la DADP y la DGTIC pongan en marcha en forma conjunta un plan de actualización y mejora continua sobre los aspectos funcionales y tecnológicos del SIGADE que garanticen la confidencialidad, integridad y disponibilidad de la información del sistema para conformar un adecuado entorno de administración del ciclo de vida de los instrumentos de deuda pública.

8. LUGAR Y FECHA

BUENOS AIRES, JUNIO de 2022

9. FIRMA

SEGAT
Lisandro
Emilio

Firmado digitalmente por SEGAT
Lisandro Emilio

Ing. Lisandro Segat
Jefe de Departamento de Auditoría Informática
AUDITORÍA GENERAL DE LA NACIÓN

MASSACCESI
Leandro
Horacio

Firmado digitalmente por MASSACCESI
Leandro Horacio



Auditoría General de la Nación

10. ANEXOS

ANEXO I – Comentarios del auditado



República Argentina - Poder Ejecutivo Nacional
Las Malvinas son argentinas

Nota

Número: NO-2022-49437391-APN-DGGDTYAI#MEC

CIUDAD DE BUENOS AIRES

Martes 17 de Mayo de 2022

Referencia: NOTA N°13/22-AG03 - Proyecto de Informe de Auditoría del Sistema de Gestión y Análisis de la Deuda (SIGADE) y Sistemas Relacionados

A: Dr. Miguel Ángel Pichetto (Auditoría General de la Nación),

Con Copia A:

De mi mayor consideración:

AL SEÑOR AUDITOR GENERAL

AUDITORÍA GENERAL DE LA NACIÓN

Dr. Miguel Ángel Pichetto

Tengo el agrado de dirigirme a usted con relación a la nota N° 13/22 A-05, enviada por esa Auditoría General, relativa al "Proyecto de Informe de Auditoría sobre el Sistema de Gestión y Análisis de la Deuda (SIGADE) y Sistemas Relacionados".

Al respecto, se remiten las respuestas propiciadas por la Dirección General de Tecnologías de la Información y Comunicaciones, la Dirección de Administración de la Deuda Pública y la Unidad de Auditoría Interna de esta Cartera Ministerial a los hallazgos formulados en el mencionado proyecto de informe.

Dichas respuestas obran en los documentos: IF-2022-46458559-APN-DGTTYC#MEC, IF-2022-46472001-APN-DGTTYC#MEC, IF-2022-47711131-APN-DADP#MEC y NO-2022-49324711-APN-UA#MEC, los cuales se agregan como archivos embebidos a la presente.



Auditoría General de la Nación



República Argentina - Poder Ejecutivo Nacional
Las Malvinas son argentinas

Nota

Número: NO-2022-49437391-APN-DGGDTYAI#MEC

Con la información brindada por las referidas dependencias, se da por respondida la nota de la Auditoría General de la Nación N° 13/22 - A05.

Sin otro particular saluda atte.

Digitally signed by Gestion Documental Electronica
Date: 2022.05.17 18:00:54 -03:00

Juan Jose Palavecino
Director General
Dirección General de Gestión Documental, Transparencia y Acceso a la
Información
Ministerio de Economía



Auditoría General de la Nación



República Argentina - Poder Ejecutivo Nacional
Las Malvinas son argentinas

Informe

Número: IF-2022-46472001-APN-DGTYC#MEC

CIUDAD DE BUENOS AIRES
Martes 10 de Mayo de 2022

Referencia: Respuesta AGN

Por medio de la presente se informa que en archivos embebidos se vinculo el documento Respuesta AGN

Digitally signed by Gestion Documental Electronica
Date: 2022.05.10 17:03:42 -03:00

Marcelo Cassino
Director General
Dirección General de Tecnologías de la Información y las Comunicaciones
Ministerio de Economía

Digitally signed by Gestion Documental
Electronica
Date: 2022.05.10 17:03:42 -03:00



Auditoría General de la Nación



República Argentina - Poder Ejecutivo Nacional
Las Malvinas son argentinas

Informe

Número: IF-2022-46458559-APN-DGITYC#MEC

CIUDAD DE BUENOS AIRES
Martes 10 de Mayo de 2022

Referencia: Auditoria_Sigade

Por medio de la presente se informa que en archivos embebidos se vinculo el documento Auditoria_Sigade

Digitally signed by Gestion Documental Electronica
Date: 2022.05.10 16:39:27 -03:00

Marcelo Cassino
Director General
Direccion General de Tecnologías de la Información y las Comunicaciones
Ministerio de Economía

Digitally signed by Gestion Documental
Electronica
Date: 2022.05.10 16:39:28 -03:00



Auditoría General de la Nación



República Argentina - Poder Ejecutivo Nacional
Las Malvinas son argentinas

Informe

Número: IF-2022-47711131-APN-DADP#MEC

CIUDAD DE BUENOS AIRES

Jueves 12 de Mayo de 2022

Referencia: EX-2022-45952475- -APN-DGDA#MEC - Proyecto de Informe de Auditoría del Sistema de Gestión y Análisis de la Deuda (SIGADE) y Sistemas Relacionados

A LA SECRETARÍA LEGAL Y ADMINISTRATIVA

Se adjunta embebido al presente archivo en respuesta a los hallazgos plasmados en el proyecto de la referencia, en cuanto a lo que es materia de competencia de esta Dirección con relación al objeto de esta auditoría.

Sirva la presente de atenta nota de envío.

Digitally signed by Gestion Documental Electronica
Date: 2022.05.12 18:45:52 -03:00

Adriana Beatriz Altieri
Directora
Direccion de Administracion de la Deuda Publica
Ministerio de Economia

Digitally signed by Gestion Documental
Electronica
Date: 2022.05.12 18:45:52 -03:00



Auditoría General de la Nación



República Argentina - Poder Ejecutivo Nacional
Las Malvinas son argentinas

Nota

Número: NO-2022-49324711-APN-UAI#MEC

CIUDAD DE BUENOS AIRES

Martes 17 de Mayo de 2022

Referencia: EX-2022-45952475- -APN-DGDA#MEC - Proyecto de Informe AGN

A: Paola Soledad Frontera (DCYCP#MEC),

Con Copia A:

De mi mayor consideración:

SEÑORA DIRECTORA:

Me dirijo a usted en el marco de la PV-2022-48638385-APN-DCYCP#MEC, mediante la cual remite las actuaciones de la referencia con la copia del Proyecto de Informe de Auditoría sujeto a discusión sobre "Sistema de Gestión y Análisis de la Deuda SIGADE y sistemas relacionados", emitido por la Auditoría General de la Nación.

Al respecto y atento lo expuesto por la AGN en el punto 4.1.2. del proyecto de informe precitado, esta Unidad manifiesta que, si bien no se realizó una auditoría interna específica de TI sobre el Sistema SIGADE (desarrollo propio de la UNCTAD), esta dependencia evalúa en las distintas auditorías que se efectúan en el ámbito de la Secretaría de Finanzas, la funcionalidad del SIGADE en los procesos llevados a cabo por las distintas áreas de la citada Secretaría, con relación a la registración de la deuda pública en dicho sistema, exponiendo los resultados arribados en los respectivos informes de auditoría.

En ese sentido, a continuación se detallan los últimos informes emitidos por esta Unidad; a saber:

Informe UAI N°62/2016. Sistema de Regularización de la Deuda Pública (SRDP).

Informe UAI N°60/2017 Servicio de la Deuda. Registración de Operaciones con Títulos Públicos y Letras del



Auditoría General de la Nación

Tesoro.

Informe UAI N° 30/2018 Administración de la Deuda Pública- Préstamos.

Informe UAI N° 26/2018 ONCP-Registración de Operaciones de Pago a Organismos Multilaterales de Crédito.

Informe UAI N° 25/2020 Registro de Deuda Indirecta y Créditos a Cobrar (RECAC).

Informe UAI N° 24/2021 Evolución de la Deuda y Aplicación de los Recursos (2016-2019).

Informe UAI N° 20/2021 Cuenta de Inversión ONCP año 2020.

Sin otro particular saluda atte.

Digitally signed by Gestión Documental Electrónica
Date: 2022.05.17 13:42:29 -03:00

Delma Viviana Daza
Auditor Interno Titular
Unidad de Auditoría Interna
Ministerio de Economía

Digitally signed by Gestión Documental
Electrónica
Date: 2022.05.17 13:42:30 -03:00



Auditoría General de la Nación

OBSERVACIONES DE LA DGTIYC SOBRE LOS HALLAZGOS DESCRIPTOS EN EL INFORME

4.1.1

Respecto de la referencia "ITIL – fase – Operación del Servicio", COBIT DS8 y DS10, la DGTIC tiene implementado desde hace 20 años un sistema de gestión de incidentes y problemas denominado CRM que contempla todos los puntos de COBIT DS8:

DS8.1: Mesa de Servicio: dentro del organigrama de la DGTIC, está implementada por la Coordinación de Mesa de Servicio y Atención al Usuario.

DS8.2: Registro de consulta de clientes: accesible desde la Intranet para autogestión, o asistido por operadores de la Mesa vía telefónica, o email: informatica@mecon.gob.ar.

DS8.3: Escalamiento de incidentes: existe una wiki interna que tiene documentado el escalamiento de problemas para los operadores de la mesa de servicio.

DS8.4: Cierre de incidentes: el sistema no sólo permite al usuario iniciador del reclamo interactuar con el operador, sino que puede acordar con el mismo el cierre, y además habilita una encuesta de satisfacción ante el cierre del caso.

También existe en el portal interno del Ministerio una encuesta general que permite opinar y/o reclamar por los servicios de TI. (ENLACE).

En el Anexo I se adjunta copia del procedimiento, y una copia de un correo a modo de ejemplo enviado por el sistema CRM conteniendo datos sobre el ticket cerrado y un enlace a la encuesta de satisfacción, ubicada en la Intranet del Ministerio.

En cuanto a las necesidades de TI y su relevamiento, en caso de existir una necesidad por parte del área usuaria, el requerimiento es hecho por la misma a la DGTIC y en dicho caso la DGTIC contacta al área usuaria para determinar el alcance del requerimiento, lo que eventualmente puede requerir de un relevamiento. Es decir, los requerimientos a la DGTIC por parte de las áreas del Ministerio funcionan por demanda del interesado.

A la fecha de esta respuesta, no existen requerimientos del área usuaria sobre necesidades relacionadas con el sistema SIGADE.

De lo expuesto anteriormente, no se observa que exista una relación entre la supuesta ausencia de acción de la DGTIC respecto de relevamientos, encuestas y/o las buenas prácticas mencionadas, y que dicha inacción derive en debilidades de seguridad relacionadas con el sistema SIGADE, o ignorancia por parte de la DGTIC sobre demandas insatisfechas relacionadas con dicho sistema.

4.2.1

La norma de cumplimiento obligatorio para los organismos de la APN en materia de seguridad de la información es la decisión administrativa 641/2021, que toma como base la norma ISO 27002. Al momento de realización de esta auditoría, la norma vigente era la D.A. 1/2015 de la Oficina Nacional de Tecnologías de la Información (ONTI), que también estaba basada en las buenas prácticas recomendadas por la norma ISO 27002.

Por lo tanto, en lo que respecta a Seguridad de la Información, el Ministerio tiene como objetivo cumplir con la D.A. vigente que, entre otros, abarca los aspectos de organización de la seguridad, los cuales a la fecha de esta opinión se encuentran cumplidos.

4.2.3



Auditoría General de la Nación

El enfoque de prevención, detección y mitigación de amenazas y vulnerabilidades en materia de seguridad informática es integral sobre toda la infraestructura tecnológica, dada la magnitud de activos de información gestionados, servicios brindados y aplicaciones desarrolladas y mantenidas.

Una de las estrategias de seguridad implementadas en la red del Ministerio de Economía es la estrategia de “defensa en capas”. La red del Ministerio de Economía (y los ministerios que utilizan servicios de la misma) se encuentra sujeta, en su totalidad, a la inspección automática de tráfico. Esta inspección se encarga de detectar patrones inusuales y, en caso de detectarlos, avisar mediante alertas o bien bloquear el tráfico. Esto es conocido como defensa de las capas de ruteo y transporte. Las defensas de las capas física y de enlaces se encuentran asociadas a elementos físicos que unen la red y los servidores, cuya estructura puede verse en los planos de red y arquitectura de red y de los cuales puede concluirse que, a la fecha, no existen vulnerabilidades externas que puedan afectarlos.

Las defensas de las capas de sesión y de aplicaciones, están más asociadas con el entorno de la aplicación y la seguridad punto a punto, o cliente - servicio. La capa de sesión se encarga de la encriptación y/o autenticación, mediante el protocolo HTTPS. El Ministerio utiliza certificados digitales de líderes de mercado con la suficiente longitud de clave de encriptación que impide a la técnica de “fuerza bruta” vulnerar la seguridad de la comunicación. Se adjunta imagen de los registros del inspector de tráfico, a modo de ejemplo.

La capa de aplicación se asegura en los procesos de desarrollo de la aplicación, que para el caso del sistema SIGADE debería haber sido contemplado por la UNCTAD, quien es el proveedor del sistema en forma de “enlatado”. La DGTIC no posee los programas “fuente” del sistema, ni tuvo intervención en las etapas del desarrollo de dicho software enlatado. El servicio de la DGTIC se limita al servicio de alojamiento del software en la infraestructura tecnológica del Ministerio y garantizar la seguridad en las capas que le compete, tal cual se ha mencionado anteriormente, y eventualmente realizar alguna operación que requiere privilegios de administrador ante el pedido del área usuaria.

Dicho lo anterior, las pruebas de penetración generales efectuados en distintos momentos a nivel aplicación no han detectado vulnerabilidades en este sistema. No obstante, queda pendiente retomar la rutina de pruebas de penetración, la que fue interrumpida por fuga del personal idóneo asignado a esa tarea.

4.2.4.

El informe dice que *“dichos procedimientos ponen en riesgo la prevención y detección temprana de anomalías en la ejecución de transacciones y de actividades no autorizadas de procesamiento de información que pueden afectar la integridad de los datos del SIGADE”*, mientras que en i) se dice que *“no se cuenta con documentación del análisis y la designación de las tablas del sistema que se consideraban críticas, a fin de justificar cuáles de ellas deben ser auditadas, y que a su vez, permita generar procedimientos que dicten cuáles serán los criterios para su control y revisión”*

El análisis y la designación de las tablas que se consideran críticas fue hecho en su momento en conjunto con el personal de la DADP, y si bien no fue documentado, esto no significa que los procedimientos aplicados sobre las tablas de auditoría pongan en riesgo la prevención y detección temprana de anomalías en la ejecución de transacciones.

No obstante, personal de la DGTIYC pudo probar y constatar que la última versión del sistema corrigió los errores de generación de registros de auditoría, pudiéndose auditar ahora todos los módulos del sistema. Se adjunta captura de pantalla de la configuración actual de la auditoría y los



Auditoría General de la Nación

registros de auditoría generados recientemente se encuentran en el documento IF-2022-46458559-APN-DGTIYC#MEC.

En iii) *“no se están auditando las modificaciones realizadas por los administradores de la base de datos sobre la tabla de amortizaciones, a la vez que tampoco se registra el usuario que realiza movimientos sobre ella”.*

Personal de la DGTIYC pudo probar y constatar que la última versión del sistema corrigió los errores de generación de registros de auditoría, pudiéndose auditar ahora todos los módulos del sistema, e incluye la tabla mencionada.

En *“iv) resulta dificultoso llevar la trazabilidad que permita vincular los registros de las tablas de auditoría del sistema con los tickets de la Mesa de Servicios que justificaron las operaciones realizadas por los administradores, a demanda de los usuarios superiores de la DADP, en las intervenciones manuales sobre la base de datos”.*

La dificultad mencionada sobre la trazabilidad no impide la vinculación. De hecho, es un cruce sencillo de vista de tablas de tickets. En todos los tickets figura:

- Usuario del área sustantiva que solicita el cambio;
- La descripción detallada del cambio;
- Administrador que la realizó, fecha y hora.

En *“vi) las tablas de auditoría son accesibles a los administradores de la base de datos y no se auditan los movimientos que éstos pudieran realizar sobre ellas.”*

Todas las tablas de todos los sistemas en cualquier ámbito u organización se encuentran técnicamente accesibles a los administradores del servidor y/o aplicación, estén o no encriptados sus datos. Cualquier actividad no autorizada producto del escalamiento de privilegios se encuentra penada por la ley 26.388 de delitos informáticos.

Respecto de las recomendaciones de “buenas prácticas” ISO 27002 y CoBIT 4.1, se reitera lo dicho en 4.2.1.

4.3.1

Al auditor se le ha comentado en una entrevista que el sistema SIGADE fue asimilado por la DGTIC luego de estar en fase de implementación el plan de recuperación ante desastres y que se incluiría al SIGADE en la próxima prueba del plan.

4.3.2

La DGTIC posee procesos implementados de pruebas de recuperación de la información existente en cintas de respaldo, y es un proceso que se ejecuta de manera regular. Dada la escala y magnitud de servicios críticos manejados por esta Dirección, es materialmente imposible verificar por cada sistema crítico la recuperación exitosa de un respaldo específico. Lo materialmente posible es tomar muestras aleatorias del respaldo general del centro de cómputos y verificar su disponibilidad, y es lo que se ejecuta en forma cotidiana. Se documentará el mismo.

4.6.1



Auditoría General de la Nación

Las áreas que requieren desarrollos y/o correcciones de sistemas y/o mejoras, efectúan el pedido a la Subsecretaría de Administración y Normalización Patrimonial (de la cual depende la DGTIC), quien en conjunto con la DGTIC evalúa, en base a los proyectos y desarrollos en curso existentes y sus prioridades, la disponibilidad de recursos para el nuevo requerimiento.

La DGTIC elabora y obtiene aprobación por parte de las autoridades de su Plan Estratégico de TI de 3 años (corto, mediano y largo plazo), según la normativa vigente.

Su actualización se aprueba anualmente. Cualquier modificación al Plan Estratégico requiere de una reprogramación, la cual debe ser aprobada nuevamente por las autoridades.

Hasta la fecha de esta respuesta al informe de auditoría, la DGTIC no tiene ni tuvo pedidos del área sustantiva relacionados con el tema mencionado.

4.6.2

Dadas las características de deuda argentina, la única forma de reflejar en el sistema ciertos cambios específicos es a través de sentencias SQL. Las modificaciones a la base se solicitan por ticket a la Mesa de Servicios de la DGTIC, que los deriva al Administrador, quien recibe la captura de dichos tickets. En todos los tickets figura:

- Usuario del área sustantiva que solicita el cambio;
- La descripción detallada del cambio;
- Administrador que la realizó, fecha y hora.

Con respecto al uso genérico del usuario administrador, algunas intervenciones sólo se pueden realizar con los privilegios del usuario Administrador del sistema (usuario DMFASVWS), ejemplo actualizar la versión del sistema y/o modificar comportamientos del sistema a través del panel de control del sistema. Para las demás operaciones, cada administrador tiene su usuario creado en el sistema. Las sentencias SQL pasarán a ejecutarse con el usuario de cada administrador.

Procedimiento de registro y derivación / escalamiento de tickets

Ingreso de solicitudes de usuario y tratamiento de tickets – WikiFICI
http://wikifici.mecon.ar/index.php/Ingreso_de_solicitudes_de_usuario...

Ingreso de solicitudes de usuario y tratamiento de tickets

De WikiFICI



Auditoría General de la Nación

Contenido

- 1 Objetivo
- 2 Alcance
- 3 Responsabilidades
- 4 Descripción
- 5 Registros
- 6 Indicadores y Estadísticas
- 7 Documentos

Relacionados

8 Archivo: Desempeño del
ficista.pdf

Objetivo

Este procedimiento tiene como fin mostrar como es el ingreso de solicitudes de usuarios y el tratamiento de tickets dentro de la Mesa de Servicio y Atención al Usuario.

Alcance

Operadores de la Mesa de Servicio y Atención al Usuario.

Responsabilidades

1. Responsable: Coordinación de Mesa de Servicio y Atención al Usuario
2. Interactuantes: Coordinación de Mesa de Servicio y Atención al Usuario, Usuarios, Coordinación de operaciones, Técnicos.

Descripción

Los integrantes del área Coordinación de Mesa de Servicio y Atención al Usuario realizan soportes a los usuarios de los ministerios a los que presta servicios informáticos la Dirección General de Tecnologías de la Información y las Comunicaciones. Entre los soportes que se realizan pueden mencionarse algunos como: ABM de usuarios, configuración y mantenimiento de perfil, altas y conflictos de red, instalaciones de soft, configuraciones de red, soporte de aplicaciones (Procesador de Textos, Planilla de Cálculos, Presentaciones, Base de Datos, etc.), configuración de agendas, dictado de cursos, asistencia en diferentes sistemas, entre otros. Debe incluirse también el testeado previo a la implementación de sistemas, migraciones, soportes especiales, capacitación por convenios. Todos los soportes son ingresados en la base de datos del CRM (sistema registral de tickets de interacción con el usuario).

1. El usuario recibe indicaciones de lo que debe hacer para solucionar el inconveniente o para despejar sus dudas.
2. Otra posibilidad es pedirle al usuario que ejecute un programa de acceso remoto (VNC). En el caso del



Auditoría General de la Nación

Ingreso de solicitudes de usuario y tratamiento de tickets – WikiFICI
http://wikifici.mecon.ar/index.php/Ingreso_de_solicitudes_de_usuario...

primero, si el usuario no ejecuta dicho programa, el operador de la Mesa de Servicio no se puede acceder a la PC. Una vez abierto, el usuario tiene que suministrar el IP o nombre de la PC para que el operador pueda conectarse a su equipo. Finalmente, el usuario debe aceptar la conexión. El operador puede observar el puesto de trabajo y trabajar en la máquina del usuario como si se estuviera sentado frente a ella. El usuario sigue paso a paso los comandos que realiza el operador a través de su pantalla. Una vez finalizado el soporte se solicita al usuario que cierre el VNC para dar por finalizado el vínculo.

3. En caso de no quedar resuelto el problema a través de este medio, se realiza un soporte presencial.

4. Algunos soportes culminan en partes técnicos, cuando es necesaria la intervención de personal técnico (Sistema de soporte técnico), o bien en una solicitud por SSO al sector de la Coordinación de operaciones (puede quedar resuelto en dicha instancia o puede darse su posterior derivación al sector de la Dirección de Desarrollo).

Registros

CRM – ■ Nuevo Soporte Diario.
SSO ■
Sistema ■ de administración de partes técnicos

Indicadores y Estadísticas

Documentos Relacionados

Identificación	Descripción	Origen	Interno	Externo
Guardias técnicas pasivas	Detalla cómo se realizan las guardias para el Ministro y sus colaboradores.	Coordinación Mesa de Servicio y Atención al Usuario	X	

Archivo: Desempeño del ficista.pdf

Fecha	Versión	Descripción/Resumen de los cambios	Autor
Marzo 2020	2.0.10	Versión Inicial	Coordinación de Mesa de Servicio y Atención al Usuario

Obtenido de "http://wikifici.mecon.ar/index.php/Ingreso_de_solicitudes_de_usuario_y_tratamiento_de_tickets"

Categorías: Procedimientos | Coordinación de Mesa de Servicio y Atención al Usuario

- Esta página fue modificada por última vez el 15:38, 29 oct 2020.
- **Correo electrónico de cierre de ticket y enlace a la encuesta de satisfacción**
-
- De: "crm" <crm@mecon.gov.ar>



Auditoría General de la Nación

- Para: "Dirección General de Tecnologías Informáticas y Comunicaciones"
<informatica@mecon.gov.ar>
- Enviados: Miércoles, 27 de Abril 2022 13:52:23
- Asunto: Su pedido a Informática ha sido resuelto
-
- Estimado usuario,
-
- Se ha cerrado su pedido a Informática número 901943
- Tipos de problemas: ABM: Servicio
- A fin de seguir mejorando nuestra atención le solicitamos que se tome un minuto para completar la siguiente encuesta sobre la calidad de servicio que recibió de nuestra parte:
- https://encuesta.mecon.ar/siem/llevar/encuesta/1/login/informatica_mecon/caso/901943/fco/mp/8249c1f7d52764234043cb94e00f50b9
-
- Muchas gracias por su tiempo.
- El equipo de Mesa de Servicio y Atención al Usuario.
- **No responda a este mensaje, ya que el remitente es una casilla automática.**

Registros de eventos generados por el inspector de tráfico

Time	Base	Action	Type	Severity	Conditione...	St...	Perf...	Source	Source...	Client...	Source...	Server type	Destination	Attack Name
Today, 17:17:15	IPS	Prevent	Log	High	High			89.248.169.6					icmin-salon-oj...	Scanner Enforcement Violation
Today, 17:17:15	IPS	Prevent	Log	High	High			89.248.169.6					rcmn (10.8.16.13)	Scanner Enforcement Violation
Today, 17:17:13	IPS	Prevent	Log	CritL	MedL			152.67.35.9					iedmine.dgsl...	Web Server Enforcement Violation
Today, 17:17:36	IPS	Prevent	Log	High	High			89.248.169.6					stems.mecon...	Scanner Enforcement Violation
Today, 17:17:36	IPS	Prevent	Log	High	High			89.248.169.6					conferencia...	Scanner Enforcement Violation
Today, 17:17:35	IPS	Prevent	Log	High	High			89.248.169.6					dispace_nut (...)	Scanner Enforcement Violation
Today, 17:17:31	IPS	Prevent	Log	CritL	MedL			152.67.35.9					rtioutsadovl...	Web Server Enforcement Violation
Today, 17:16:39	IPS	Accept	Log	Info...	N/A			125.44.38.21					gpcuidados...	
Today, 17:16:15	IPS	Accept	Log	Info...	N/A			125.44.251.29					paentz_nut (...)	
Today, 17:15:30	IPS	Prevent	Log	CritL	MedL	1		152.67.35.9					dmu2_medin...	Web Server Enforcement Violation
Today, 17:14:37	IPS	Prevent	Log	CritL	MedL	1		152.67.35.9					dgslaf_meco...	Web Server Enforcement Violation
Today, 17:14:17	IPS	Prevent	Log	CritL	MedL	1		152.67.35.9					medha_nut (...)	Web Server Enforcement Violation
Today, 17:14:01	IPS	Prevent	Log	CritL	MedL	1		152.67.35.9					Web-Server...	Web Server Enforcement Violation
Today, 17:13:59	IPS	Prevent	Log	CritL	MedL	1		152.67.35.9					dmu1_tramit...	Web Server Enforcement Violation
Today, 17:13:13	IPS	Prevent	Log	CritL	MedL	1		152.67.35.9					ikimecon...	Web Server Enforcement Violation
Today, 17:13:05	IPS	Prevent	Log	CritL	MedL	1		152.67.35.9					tst-plan-gas...	Web Server Enforcement Violation
Today, 17:12:14	IPS	Prevent	Log	CritL	MedL	3		birferno-web...					172.27.10.35	Web Server Enforcement Violation
Today, 17:12:10	IPS	Prevent	Log	Mod...	High	1		172.104.119.48					dmu1_tramit...	Web Server Enforcement Violation
Today, 17:12:10	IPS	Prevent	Log	CritL	MedL	1		172.104.119.48					dmu1_tramit...	Web Server Enforcement Violation
Today, 17:12:10	IPS	Prevent	Log	CritL	MedL	1		172.104.119.48					dmu1_tramit...	Apache Server Protection Violation
Today, 17:10:35	IPS	Prevent	Log	CritL	MedL	1		95.211.246.87.201					apps.dgslaf...	Application Server Protection Violation
Today, 17:00:48	IPS	Prevent	Log	CritL	MedL	1		14.53.216.85					dmu1_www2...	Application Server Protection Violation
Today, 17:00:20	IPS	Prevent	Log	CritL	MedL	1		27.131.0.8					dgslaf_meco...	Web Server Enforcement Violation
Today, 17:00:01	IPS	Prevent	Log	CritL	MedL	1		27.131.0.8					dgslaf_meco...	Web Server Enforcement Violation
Today, 17:00:00	IPS	Prevent	Log	CritL	MedL	1		27.131.0.8					dgslaf_meco...	Web Server Enforcement Violation
Today, 16:59:33	IPS	Prevent	Log	CritL	MedL	1		120.66.236.105					tw200_slmec...	Application Server Protection Violation
Today, 16:58:20	IPS	Prevent	Log	CritL	MedL	1		221.15.188.22					prod-sic_net...	Web Server Enforcement Violation

Captura de pantalla del módulo de configuración de auditoría

Nota: el indicador verde a la izquierda de cada módulo indica que la auditoría se encuentra activada para todos los sub-módulos de ese módulo. En caso de existir activación parcial, el indicador es amarillo, y en caso de ausencia total, el indicador es rojo.



Auditoría General de la Nación

La imagen muestra la interfaz de usuario del SIGADE (Sistema Integrado de Gestión de Auditoría) en un navegador web. La URL es 10.12.8.95:8080/dmfas/entrypoint.jsp. El menú de navegación a la izquierda incluye: Parámetros del SIGADE, Seguridad, Listas de valores, Traducciones, Soporte, Auditoría, Validación de datos, Procesos en segundo plano y Herramientas. El título de la ventana es "Definir los parámetros de auditoría del SIGADE".

El formulario principal está dividido en dos pestañas: "Parámetros de auditoría" (seleccionada) y "Historial de los parámetros de auditoría".

En la pestaña "Parámetros de auditoría", se encuentran los siguientes campos y opciones:

- Usuario:** dmfasvws
- Fecha creación:** 19/05/2022
- Hora:** 13:42
- ☒ ¿Activar la auditoría?
- ☐ ¿Activar los mensajes en caso de modificaciones?
- ☒ ¿Activar el filtro por instrumento?

Debajo de estas opciones, hay una lista de módulos de auditoría (DMFAS Modules) con sus respectivos permisos:

- SELECT ☒
- INSERT ☒
- UPDATE ☒
- DELETE ☒
- EXECUTE ☒
- DETAILS ☒
- Utilities ☐
- Mobilize ☐
- Debt Service ☐
- Negotiation ☐
- Reports ☐
- Administration ☐
- Control Panel ☐
- Analysis ☐

En la parte inferior derecha del formulario, hay dos botones: "Guardar" y "Salir".

ACLARACIONES DADP SOBRE HALLAZGOS DE AGN A LA AUDITORÍA DEL SIGADE

4.4.1. El Manual de Procesos utilizado por la DADP como guía para la ejecución de los procesos operativos de registración, seguimiento y control de los instrumentos de deuda se encuentra desactualizado, lo que conlleva el riesgo de los agentes intervinientes en la ejecución diaria de los procedimientos de registración, seguimiento y control de los instrumentos de deuda apliquen acciones temporales.

Que el Manual de Procesos se encuentre desactualizado no implica que los procesos que allí se describen no se cumplan o que se cumplan parcialmente. La utilización del sistema GDE y la integración del SIGADE al módulo de gastos del SIDIF, han significado cambios que no alteran la esencia de los procesos del Manual, lo cual tampoco implica que se desconozca la necesidad de su actualización.



Auditoría General de la Nación

ANEXO II – Análisis de los comentarios del Auditado

Sección del Informe	Comentario del Auditado	Análisis del Comentario
4.1. Gobierno de TI 4.1.1. <i>La DGTIC no ha realizado un relevamiento integral de los activos de TI, los procesos, las necesidades y el nivel de satisfacción de los usuarios en el ámbito de la DADP. Esta situación conduce al desconocimiento de la opinión de los usuarios respecto a los problemas, debilidades y requerimientos funcionales y técnicos del SIGADE, y del nivel de satisfacción de los usuarios con el sistema y la calidad de los servicios de TI brindados por la DGTIC y por la UNCTAD.</i> En base al análisis de la documentación provista y de las entrevistas mantenidas con las áreas de servicio de la DGTIC y con las principales áreas operativas de la DADP, se verificó que la DGTIC no realiza relevamientos con la comunidad usuaria vinculada al entorno SIGADE, sobre los procesos operativos ejecutados, las reglas de negocio, las necesidades funcionales y tecnológicas de los usuarios de las distintas coordinaciones integrantes de la DADP, ni de los niveles de satisfacción del servicio de TI brindado por la DGTIC y del servicio de soporte y mantenimiento continuo del SIGADE a cargo de la UNCTAD. Las buenas prácticas referidas a la gestión de usuarios indican que los relevamientos y encuestas de satisfacción de los usuarios respecto de requerimientos funcionales y tecnológicos y de los niveles de servicios de TI brindados constituyen una herramienta de vital importancia para realizar las acciones correctivas, evolutivas y adaptativas sobre los servicios de TI y las aplicaciones de acuerdo a los requerimientos dinámicos del negocio (ITIL - fase: Operación del Servicio y CobIT v4.1 - DS8: Administrar la Mesa de Servicio y los Incidentes y -	Respecto de la referencia “ITIL – fase – Operación del Servicio”, COBIT DS8 y DS10, la DGTIC tiene implementado desde hace 20 años un sistema de gestión de incidentes y problemas denominado CRM que contempla todos los puntos de COBIT DS8: DS8.1: Mesa de Servicio: dentro del organigrama de la DGTIC, está implementada por la Coordinación de Mesa de Servicio y Atención al Usuario. DS8.2: Registro de consulta de clientes: accesible desde la Intranet para autogestión, o asistido por operadores de la Mesa vía telefónica, o email: informatica@mecon.gob.ar. DS8.3: Escalamiento de incidentes: existe una wiki interna que tiene documentado el escalamiento de problemas para los operadores de la mesa de servicio. DS8.4: Cierre de incidentes: el sistema no sólo permite al usuario iniciador del reclamo interactuar con el operador, sino que puede acordar con el mismo el cierre, y además habilita una encuesta de satisfacción ante el cierre del caso. También existe en el portal interno del Ministerio una encuesta general que permite opinar y/o reclamar por los servicios de TI. (ENLACE). En el Anexo I se adjunta copia del procedimiento, y una copia de un correo a modo de ejemplo enviado por el sistema CRM conteniendo datos sobre el ticket cerrado y un enlace a la encuesta de satisfacción, ubicada en la Intranet del Ministerio. En cuanto a las necesidades de TI y su relevamiento, en caso de existir una necesidad por parte del área usuaria, el requerimiento es hecho por la misma a la DGTIC y en dicho caso la DGTIC contacta al área usuaria para determinar el alcance del requerimiento,	De acuerdo a lo informado por el auditado en nota Nro. IF-2020-90703377-APN-DGTIC#MEC en respuesta a la nota AGN Nro. 59/20-AG03, y en función de lo relevado en las reuniones mantenidas por este equipo de auditoría con personal de la DGTIC y con los usuarios de la DADP, se ha constatado que durante el período auditado no se realizaron relevamientos proactivos a las áreas usuarias para conocer sus necesidades funcionales, tecnológicas o del nivel de satisfacción de los usuarios con el SIGADE. La respuesta del auditado no invalida lo manifestado sobre los hechos que sustentan la observación. En efecto, los procesos descriptos en la respuesta no desconocen ni contradicen las conclusiones arribadas. Por lo tanto, se mantiene el hallazgo.



Auditoría General de la Nación

Sección del Informe	Comentario del Auditado	Análisis del Comentario
DS10: Administración de Problemas). Que no se realicen y documenten estos relevamientos impacta en el nivel de conocimiento de la DGTIC sobre los problemas y las necesidades técnicas y funcionales de los usuarios del SIGADE, ocasionando que no se tomen acciones correctivas, evolutivas y adaptativas de manera planificada sobre el sistema como parte de un plan formalizado de mejora continua, esto último tiene vinculación directa con lo indicado en los hallazgos 4.5.1 y 4.6.1.	lo que eventualmente puede requerir de un relevamiento. Es decir, los requerimientos a la DGTIC por parte de las áreas del Ministerio funcionan por demanda del interesado. A la fecha de esta respuesta, no existen requerimientos del área usuaria sobre necesidades relacionadas con el sistema SIGADE. De lo expuesto anteriormente, no se observa que exista una relación entre la supuesta ausencia de acción de la DGTIC respecto de relevamientos, encuestas y/o las buenas prácticas mencionadas, y que dicha inacción derive en debilidades de seguridad relacionadas con el sistema SIGADE, o ignorancia por parte de la DGTIC sobre demandas insatisfechas relacionadas con dicho sistema.	
4.1.2. El SIGADE no cuenta, para su plataforma tecnológica y para los servicios de soporte y mantenimiento continuo brindados por la DGTIC, con un adecuado ambiente de control interno que garantice la detección temprana de riesgos de TI y las acciones pertinentes para mitigarlos. A partir de las entrevistas mantenidas y del análisis de la documentación provista por la supervisión de TI de la UAI del organismo, se constató que no se realizaron auditorías internas de TI sobre el SIGADE; este escenario evidencia la falta de un efectivo control interno sobre los procesos y procedimientos llevados a cabo por la DGTIC para la prestación de los servicios de TI brindados por los proveedores internos y externos. En función de lo establecido en la Res. 48/05 ²¹ (SIGEN, Art. 13 - Auditoría Interna de Sistemas), las unidades de auditoría interna definidas en la Ley N° 24.156, deben, entre otras cuestiones, contemplar la ejecución de auditorías de sistemas para efectuar revisiones objetivas de los controles	SEÑORA DIRECTORA: Me dirijo a usted en el marco de la PV-2022-48638385-APN-DCYCP#MEC, mediante la cual remite las actuaciones de la referencia con la copia del Proyecto de Informe de Auditoría sujeto a discusión sobre “Sistema de Gestión y Análisis de la Deuda SIGADE y sistemas relacionados”, emitido por la Auditoría General de la Nación. Al respecto y atento lo expuesto por la AGN en el punto 4.1.2. del proyecto de informe precitado, esta Unidad manifiesta que, si bien no se realizó una auditoría interna específica de TI sobre el Sistema SIGADE (desarrollo propio de la UNCTAD), esta dependencia evalúa en las distintas auditorías que se efectúan en el ámbito de la Secretaría de Finanzas, la funcionalidad del SIGADE en los procesos llevados a cabo por las distintas áreas de la citada Secretaría, con relación a la registración de la deuda pública en dicho sistema, exponiendo los resultados arribados en los respectivos informes de auditoría.	A partir del análisis de la documentación y de las entrevistas mantenidas con el Supervisor de TI de la UAI, y del análisis de la documentación suministrada por el auditado en su respuesta, este equipo de auditoría constata que durante el período auditado la UAI del organismo no realizó ninguna auditoría de TI sobre el SIGADE. Tal lo establecido en la Res. 48/05 (SIGEN, Art. 13 - Auditoría Interna de Sistemas), en vigencia durante el período auditado, y en la Res. 87/22 que la reemplaza (en su Art. 12), las unidades de auditoría interna definidas en la Ley N° 24.156, deben, entre otras cuestiones, contemplar la ejecución de auditorías de sistemas para efectuar revisiones objetivas de los controles informáticos y preparar informes sobre sus hallazgos y recomendaciones. Por todo lo expuesto, la respuesta del auditado no desconoce ni contradice lo observado. Por lo tanto, se mantiene el hallazgo.



Auditoría General de la Nación

Sección del Informe	Comentario del Auditado	Análisis del Comentario
informáticos y preparar informes sobre sus hallazgos y recomendaciones. Adicionalmente, las buenas prácticas referidas al control de TI (CobIT v4.1 - ME2.1: Monitorización del Marco de Trabajo de Control Interno y ME2.2: Revisiones de Auditoría) establecen que se debe monitorear de forma continua, comparar y mejorar el ambiente de control de TI y el marco de trabajo de control de TI para satisfacer los objetivos organizacionales, y se debe evaluar la eficiencia y efectividad de los controles internos de revisión de la gerencia de TI. La falta de un adecuado ambiente de control interno de TI obre el SIGADE expone a la DADP a riesgos no detectados y, por lo tanto, no mitigados	En ese sentido, a continuación se detallan los últimos informes emitidos por esta Unidad; a saber: Informe UAI N°62/2016. Sistema de Regularización de la Deuda Pública (SRDP). Informe UAI N°60/2017 Servicio de la Deuda. Registración de Operaciones con Títulos Públicos y Letras del Tesoro. Informe UAI N°30/2018 Administración de la Deuda Pública- Préstamos. Informe UAI N° 26/2018 ONCP-Registración de Operaciones de Pago a Organismos Multilaterales de Crédito. Informe UAI N° 25/2020 Registro de Deuda Indirecta y Créditos a Cobrar (RECAC). Informe UAI N° 24/2021 Evolución de la Deuda y Aplicación de los Recursos (2016-2019). Informe UAI N° 20/2021 Cuenta de Inversión ONCP año 2020.	
4.2. Seguridad de la Información 4.2.1. <i>El organismo no cuenta con un Comité de Seguridad de la Información y tampoco con una estructura organizacional adecuada para atender y gestionar las políticas y procedimientos de seguridad de la información aplicables transversalmente a toda la organización. Esta situación impacta sobre el adecuado cumplimiento de los principios de confidencialidad, integridad y disponibilidad de la información organizacional.</i> Luego de evaluada la documentación técnica provista por el organismo y de las entrevistas mantenidas con la DGTIC y con Secretaría Legal y Administrativa del Ministerio de Economía, se constató que el 6 de marzo de 2021 el Ministerio de Economía aprobó su “Política de Seguridad de la Información” (Resol. N° 99/2021, código SI-POL-01, versión 1.2), y se designó a la	La norma de cumplimiento obligatorio para los organismos de la APN en materia de seguridad de la información es la decisión administrativa 641/2021, que toma como base la norma ISO 27002. Al momento de realización de esta auditoría, la norma vigente era la D.A. 1/2015 de la Oficina Nacional de Tecnologías de la Información (ONTI), que también estaba basada en las buenas prácticas recomendadas por la norma ISO 27002. Por lo tanto, en lo que respecta a Seguridad de la Información, el Ministerio tiene como objetivo cumplir con la D.A. vigente que, entre otros, abarca los aspectos de organización de la seguridad, los cuales a la fecha de esta opinión se encuentran cumplidos.	Durante el período auditado y en la etapa de ejecución de las tareas de campo de este equipo de auditoría, el organismo no contaba con un Comité de Seguridad de la Información que diseñe e implemente un Plan de Seguridad de la Información que abarque a todo el organismo, que dicte y formalice las políticas y procedimientos de Seguridad de la Información, y que defina y establezca una estructura organizacional especializada que se encargue de la ejecución operativa del plan y del cumplimiento de las políticas y procedimientos pertinentes. Asimismo, tampoco contaba con una estructura organizacional adecuada para atender y gestionar las políticas y procedimientos de seguridad de la información aplicables transversalmente a toda la organización.



Auditoría General de la Nación

Sección del Informe	Comentario del Auditado	Análisis del Comentario
titular de la Secretaría Legal y Administrativa del Ministerio como Responsable de Seguridad de la Información del organismo. Esto evidencia que durante el período auditado el organismo no constituyó un Comité de Seguridad de la Información que diseñe e implemente un Plan de Seguridad de la Información que abarque a todo el organismo, que dicte y formalice las políticas y procedimientos de Seguridad de la Información, y que defina y establezca una estructura organizacional especializada que se encargue de la ejecución operativa del plan y del cumplimiento de las políticas y procedimientos pertinentes. En función de lo que establecen las buenas prácticas en la materia (ISO 27001 - Aspectos organizativos para la Seguridad de la Información; CobIT v4.1 - DS5.1: Administración de la Seguridad de TI y DS5.2: Plan de Seguridad de TI), toda organización debe administrar adecuadamente la Seguridad de la Información a partir de los siguientes aspectos: i) concientizar internamente a la organización sobre la necesidad de implementar y cumplir con políticas y procedimientos que garanticen la salvaguarda de los activos de información de la organización y del negocio; ii) conformar un Comité de Gestión de Seguridad de la Información que dicte, formalice, controle y actualice las políticas y procedimientos de Seguridad de la Información; iii) asignar una estructura técnica especializada contando con todos los medios, recursos e insumos técnicos necesarios, dependiente de las máximas autoridades de la organización, para que se responsabilice de la administración integral de la Seguridad de la Información. Que el organismo no implemente y mantenga en el tiempo estas buenas prácticas vinculadas a la Seguridad de la Información a nivel		Las acciones tomadas por el organismo con posterioridad al período auditado serán tenidas en cuenta en oportunidad de autorizarse futuros proyectos de auditoría. Por lo tanto, se mantiene el hallazgo.



Auditoría General de la Nación

Sección del Informe	Comentario del Auditado	Análisis del Comentario
organizacional pone en riesgo el cumplimiento de los principios de confidencialidad, integridad y disponibilidad de la información organizacional.		
4.2.2. <i>Los niveles de acceso otorgados en el SIGADE a los usuarios de la DADP no se corresponden con las funciones según el perfil que poseen los agentes usuarios del sistema, lo que compromete la segregación de funciones y ponen en riesgo la integridad, disponibilidad y confidencialidad de la información.</i> Del análisis de la documentación remitida por el auditado, y de las reuniones mantenidas con personal técnico de la DGTIC y con usuarios de distintos niveles jerárquicos de la DADP, se constató que todos los usuarios con cuentas de usuario activas en el SIGADE poseen, dentro del sistema, el mismo perfil y las mismas funciones a través del rol “Operador”, lo que permite a todos estos usuarios un acceso transversal a las funcionalidades y a la información registrada en el sistema, sin contemplar la función, responsabilidades o área a la que pertenezca cada uno de estos usuarios. Este escenario no garantiza una adecuada separación por funciones dentro del SIGADE; además, la configuración de acceso de usuarios aplicada al momento de esta auditoría no permite que por el sistema se pueda controlar que un usuario perteneciente a una coordinación no acceda sin autorización, a información de otra coordinación. Cabe aclarar que el SIGADE, a través de la configuración de usuarios, permite acotar las funcionalidades específicas para cada uno de ellos, pero estas restricciones no se aplican por decisión directiva. Por último, se verificó que el sistema no posee alertas de operaciones que permitan el control de las actividades ejecutadas por los usuarios. Las	Sin comentarios.	Se mantiene el hallazgo.



Auditoría General de la Nación

Sección del Informe	Comentario del Auditado	Análisis del Comentario
buenas prácticas en gestión de usuarios (CobIT v4.1 - DS 5.4: Administración de cuentas de usuario, PO 7.3: Asignación de roles, PO 7.8: Cambios y terminación de trabajo; ISO 27002 - 11.2.1 Registro de usuarios, 11.2.2 Gestión de privilegios, 10.1.3 Segregación de funciones) establecen que se debe verificar que el nivel de acceso otorgado se corresponda con los perfiles y las funciones establecidas para cada perfil y que sea consistente con la política de seguridad de la información del organismo, entre otras: i) que no se comprometa la separación de las tareas o segregación de funciones, ii) que se asignen los privilegios a los individuos sobre las bases de necesidad de uso en función de sus responsabilidades y funciones para cada proceso de negocio, y iii) las funciones y las áreas de responsabilidad se deben encontrar segregadas para reducir las oportunidades de modificaciones sin autorización o no intencionales. Al no estar establecidas sistemáticamente la separación de funciones y el control de acceso a los datos entre áreas, la situación observada pone en riesgo los objetivos de garantizar la confidencialidad, integridad y disponibilidad de la información del SIGADE y de reducir las oportunidades de modificaciones sin autorización o no intencionales.		
4.2.3. <i>La DGTIC no realiza pruebas de seguridad sobre el SIGADE y los sistemas relacionados, lo que no permite medir el grado de seguridad en que se encuentran estos entornos, diagnosticar y tomar acciones correctivas que minimicen los riesgos que pudieran comprometer la confidencialidad, integridad y disponibilidad de la información.</i> Del análisis de la documentación técnica entregada y de las entrevistas mantenidas con personal de la DGTIC, se constató que los procedimientos de pruebas y análisis	El enfoque de prevención, detección y mitigación de amenazas y vulnerabilidades en materia de seguridad informática es integral sobre toda la infraestructura tecnológica, dada la magnitud de activos de información gestionados, servicios brindados y aplicaciones desarrolladas y mantenidas. Una de las estrategias de seguridad implementadas en la red del Ministerio de Economía es la estrategia de “defensa en capas”. La red del Ministerio de Economía (y los ministerios que utilizan servicios de la misma) se	Ante el requerimiento por parte de este equipo de auditoría sobre la copia del documento que refleje los resultados de las pruebas de seguridad / intrusión en el período auditado, en especial las referidas al SIGADE, el auditado, mediante nota 0033 - IF-2020-73222235-APN-DE#MEC, respondió lo siguiente: “ <i>El sistema SIGADE se encuentra</i>



Auditoría General de la Nación

Sección del Informe	Comentario del Auditado	Análisis del Comentario
de seguridad informática aplicados no incluyen a las aplicaciones críticas del organismo, entre ellas al SIGADE y a los sistemas relacionados. Las buenas prácticas en seguridad de los sistemas señalan que la necesidad de mantener la integridad de la información y de proteger los activos de TI, requiere de un proceso de administración de la seguridad. Este proceso incluye, entre otros, realizar pruebas periódicas, así como realizar acciones correctivas sobre las debilidades o incidentes de seguridad identificados. Una efectiva administración de la seguridad protege todos los activos de TI para minimizar el impacto en el negocio causado por vulnerabilidades o incidentes de seguridad (CobIT v4.1 - DS5: Garantizar la seguridad de los sistemas) La falta de pruebas de seguridad informática sobre el SIGADE y su entorno generan las siguientes limitaciones: i) no permite medir, en materia de seguridad, el grado de solidez del sistema; ii) podrían no detectarse vulnerabilidades que puedan comprometer la confidencialidad, integridad y disponibilidad de la información; y iii) posibles fallas en las acciones correctivas para minimizar el impacto de las vulnerabilidades o incidentes de seguridad.	encuentra sujeta, en su totalidad, a la inspección automática de tráfico. Esta inspección se encarga de detectar patrones inusuales y, en caso de detectarlos, avisar mediante alertas o bien bloquear el tráfico. Esto es conocido como defensa de las capas de ruteo y transporte. Las defensas de las capas física y de enlaces se encuentran asociadas a elementos físicos que unen la red y los servidores, cuya estructura puede verse en los planos de red y arquitectura de red y de los cuales puede concluirse que, a la fecha, no existen vulnerabilidades externas que puedan afectarlos. Las defensas de las capas de sesión y de aplicaciones, están más asociadas con el entorno de la aplicación y la seguridad punto a punto, o cliente - servicio. La capa de sesión se encarga de la encriptación y/o autenticación, mediante el protocolo HTTPS. El Ministerio utiliza certificados digitales de líderes de mercado con la suficiente longitud de clave de encriptación que impide a la técnica de “fuerza bruta” vulnerar la seguridad de la comunicación. Se adjunta imagen de los registros del inspector de tráfico, a modo de ejemplo. La capa de aplicación se asegura en los procesos de desarrollo de la aplicación, que para el caso del sistema SIGADE debería haber sido contemplado por la UNCTAD, quien es el proveedor del sistema en forma de “enlatado”. La DGTIC no posee los programas “fuente” del sistema, ni tuvo intervención en las etapas del desarrollo de dicho software enlatado. El servicio de la DGTIC se limita al servicio de alojamiento del software en la infraestructura tecnológica del Ministerio y garantizar	<i>operativo dentro de la red LAN²⁸ del Ministerio de Economía. Dentro de la LAN no se realizan pruebas de seguridad. Análisis de seguridad tipo "test de intrusión o 'pentest' se realizan en la zona desmilitarizada DMZ²⁹".</i> Por otro lado, en una de las entrevistas mantenidas con el director de la DGTIC y en referencia a las pruebas de seguridad realizadas al SIGADE, éste manifestó que “...se realizan pruebas en la DMZ que es lo que se tiene más expuesto, pero no se están haciendo sobre los sistemas internos. No se han realizado pruebas de seguridad relativas a la confidencialidad, integridad y disponibilidad en el entorno SIGADE”. Por último, en su respuesta el auditado reconoce el hallazgo al manifestar que “(...) No obstante, queda pendiente retomar la rutina de pruebas de penetración, la que fue interrumpida por fuga del personal idóneo asignado a esa tarea”. Por todo lo expuesto, la respuesta del auditado no desconoce ni contradice lo observado. Por lo tanto, se mantiene el hallazgo.

²⁸ LAN (por sus siglas en inglés, *Local Area Network*), red de área local, es una red de computadoras que permite la comunicación y el intercambio de datos entre diferentes dispositivos a nivel local, ya que está limitada a distancias cortas. Por esta razón, esta red se utiliza para hogares privados, tales como una casa o un apartamento, y en empresas.

²⁹ DMZ (por sus siglas en inglés, *demilitarized zone*), zona desmilitarizada, se trata de una red aislada que se encuentra dentro de la red interna de la organización.



Auditoría General de la Nación

Sección del Informe	Comentario del Auditado	Análisis del Comentario
	la seguridad en las capas que le compete, tal cual se ha mencionado anteriormente, y eventualmente realizar alguna operación que requiere privilegios de administrador ante el pedido del área usuaria. Dicho lo anterior, las pruebas de penetración generales efectuados en distintos momentos a nivel aplicación no han detectado vulnerabilidades en este sistema. No obstante, queda pendiente retomar la rutina de pruebas de penetración, la que fue interrumpida por fuga del personal idóneo asignado a esa tarea.	
4.2.4. Los procedimientos aplicados por la DGTIC para la administración, evaluación y monitoreo continuo sobre las tablas de auditoría generadas por las transacciones del SIGADE, ponen en riesgo la prevención y la detección temprana de anomalías en la ejecución de transacciones y de actividades no autorizadas de procesamiento de información que pueden afectar la integridad de los datos del SIGADE. De la evaluación de la información remitida y de las entrevistas mantenidas con las áreas usuarias de la DADP y con los administradores del SIGADE, esta auditoría detectó los siguientes desvíos sobre la gestión de las pistas de auditoría del SIGADE: i) no se cuenta con documentación del análisis y la designación de las tablas del sistema que se consideraban críticas, a fin de justificar cuáles de ellas deben ser auditadas, y que a su vez, permita generar procedimientos que dicten cuáles serán los criterios para su control y revisión; ii) las tablas de auditoría no se revisan de manera periódica, a fin de detectar de manera temprana movimientos transaccionales inadecuados, tanto a través del sistema como de intervenciones manuales a la base de datos, solo se examinan cuando existe un requerimiento específico de revisión; iii) no se están auditando las	El informe dice que <i>“dichos procedimientos ponen en riesgo la prevención y detección temprana de anomalías en la ejecución de transacciones y de actividades no autorizadas de procesamiento de información que pueden afectar la integridad de los datos del SIGADE”</i>, mientras que en i) se dice que <i>“no se cuenta con documentación del análisis y la designación de las tablas del sistema que se consideraban críticas, a fin de justificar cuáles de ellas deben ser auditadas, y que a su vez, permita generar procedimientos que dicten cuáles serán los criterios para su control y revisión”</i> El análisis y la designación de las tablas que se consideran críticas fue hecho en su momento en conjunto con el personal de la DADP, y si bien no fue documentado, esto no significa que los procedimientos aplicados sobre las tablas de auditoría pongan en riesgo la prevención y detección temprana de anomalías en la ejecución de transacciones. No obstante, personal de la DGTIYC pudo probar y constatar que la última versión del sistema corrigió los errores de generación de registros de auditoría, pudiéndose auditar ahora todos los módulos del sistema. Se adjunta captura de pantalla de la configuración actual de la auditoría y los registros de	El auditado admite que no se cuenta con documentación del análisis y la designación de las tablas del sistema que se consideraban críticas (<i>“...si bien no fue documentado”</i>), a fin de justificar cuáles de ellas deben ser auditadas, y que a su vez permita generar procedimientos que dicten cuáles serán los criterios para su control y revisión. Con respecto al descargo referido al punto iv), durante las tareas de campo se le solicitó al administrador de la base de datos tickets de la Mesa de Servicios que estuvieran relacionados con pedidos de intervenciones manuales a la base de datos entre agosto de 2018 y julio de 2020 y, de ser posible, que se identificara a qué movimientos en las líneas de las tablas de auditoría corresponden y/o a qué movimientos en las líneas de las tablas que no están siendo auditadas correspondían dichos tickets. Se recibió como respuesta a dicho requerimiento que <i>“...No es posible identificar a qué tickets corresponden los movimientos de las líneas de auditoría”</i>. Por otro lado, en una de las entrevistas mantenidas con el administrador de la base de datos, éste manifestó que <i>“No se puede determinar, desde la tabla de auditoría, cuál fue el motivo que originó la intervención. Tampoco se puede conectar una</i>



Auditoría General de la Nación

Sección del Informe	Comentario del Auditado	Análisis del Comentario
modificaciones realizadas por los administradores de la base de datos sobre la tabla de amortizaciones, a la vez que tampoco se registra el usuario que realiza movimientos sobre ella; iv) resulta dificultoso llevar la trazabilidad que permita vincular los registros de las tablas de auditoría del sistema con los tickets de la Mesa de Servicios que justificaron las operaciones realizadas por los administradores, a demanda de los usuarios superiores de la DADP, en las intervenciones manuales sobre la base de datos; v) con la información registrada en las tablas de auditoría no es posible evaluar qué información fue modificada, pues en estas tablas solo se graba el registro final modificado (después del evento) no así el registro original que fuera modificado (antes del evento); en consecuencia, con la información que brindan las tablas de auditoría, no es posible determinar qué información del registro fue modificada; y vi) las tablas de auditoría son accesibles a los administradores de la base de datos y no se auditan los movimientos que éstos pudieran realizar sobre ellas. En relación a lo expuesto, las buenas prácticas sobre el seguimiento y control en la gestión de operaciones, establecen que: i) para detectar las actividades no autorizadas de procesamiento de información es recomendable que los sistemas se monitoreen y controlen para asegurar que los usuarios realicen solamente las actividades para las cuales fueron autorizados explícitamente (ISO 27002 - 10.10 Seguimiento y control); ii) se produzcan y mantengan pistas de auditoría en las cuales se registren las actividades, excepciones y eventos de seguridad de la información de los usuarios, por un período acordado para ayudar en futuras investigaciones y en el seguimiento del control de acceso. En todos los sistemas, sean automatizados o no, las pistas de	auditoría generados recientemente se encuentran en el documento IF-2022-46458559-APN-DGTIYC#MEC. En iii) <i>“no se están auditando las modificaciones realizadas por los administradores de la base de datos sobre la tabla de amortizaciones, a la vez que tampoco se registra el usuario que realiza movimientos sobre ella”</i> . Personal de la DGTIYC pudo probar y constatar que la última versión del sistema corrigió los errores de generación de registros de auditoría, pudiéndose auditar ahora todos los módulos del sistema, e incluye la tabla mencionada. En <i>“iv) resulta dificultoso llevar la trazabilidad que permita vincular los registros de las tablas de auditoría del sistema con los tickets de la Mesa de Servicios que justificaron las operaciones realizadas por los administradores, a demanda de los usuarios superiores de la DADP, en las intervenciones manuales sobre la base de datos”</i> . La dificultad mencionada sobre la trazabilidad no impide la vinculación. De hecho, es un cruce sencillo de vista de tablas de tickets. En todos los tickets figura: - Usuario del área sustantiva que solicita el cambio; - La descripción detallada del cambio; - Administrador que la realizó, fecha y hora. En <i>“vi) las tablas de auditoría son accesibles a los administradores de la base de datos y no se auditan los movimientos que éstos pudieran realizar sobre ellas.”</i> Todas las tablas de todos los sistemas en cualquier ámbito u organización se encuentran técnicamente accesibles a los administradores del servidor y/o aplicación, estén o no encriptados sus datos. Cualquier actividad no autorizada producto del escalamiento de	<i>intervención en la base con un ticket de pedido que la haya motivado”</i> . Concurrentemente, el auditado manifestó que <i>“...las intervenciones manuales a la base de datos del SIGADE no están categorizadas como para poder buscarlo por esa característica [en la tickeadora]”</i> . Con respecto al descargo referido al punto vi), durante las entrevistas mantenidas con el administrador de la base de datos, éste manifestó que <i>“Las tablas de auditoría se guardan en la base de datos del SIGADE, en el mismo disco físico. Sólo pueden tener acceso a las tablas los DBA”,</i> y que <i>“Sólo los DBA tienen permisos para modificar los triggers que generan las tablas de auditoría”,</i> y además que: <i>“Los movimientos de los DBA sobre las tablas de auditoría no están auditados”</i> . Y por último que <i>“Las tablas de auditoría no se revisan y/o monitorean con regularidad, solo ante requerimientos puntuales”</i> . Por último, con respecto a lo manifestado por el auditado en cuanto a las correcciones de los errores del sistema indicados en el hallazgo y que fueron subsanados en la nueva versión, la cual fue implementada con posterioridad a la finalización de las tareas de campo, serán tenidas en cuenta en oportunidad de autorizarse futuras auditorías. Por todo lo dicho, las respuestas del auditado no contradicen lo observado. Por lo tanto, se mantiene el hallazgo.



Auditoría General de la Nación

Sección del Informe	Comentario del Auditado	Análisis del Comentario
auditoría deben estar siempre presentes, y deben cumplir el requisito básico de que cualquier transacción generada automáticamente, pueda ser rastreada hasta el evento o condición que la generó (ISO 27002 - 10.10.1 Registro de auditoría); iii) que la información de registro esté protegida contra la manipulación y procesos no autorizados (ISO 27002 - 10.10.3 Protección de la información de los registros de actividad); y iv) realizar una efectiva administración de la seguridad protege todos los activos de TI para minimizar el impacto en la organización causado por vulnerabilidades o incidentes de seguridad (CobIT v4.1 - DS5: Garantizar la seguridad de los sistemas). Por último, las buenas prácticas sobre arquitectura de la información establecen que se debe desarrollar un diccionario corporativo de datos que contenga, entre otras cosas, el esquema de clasificación de datos y los niveles de seguridad, para mejorar la calidad de la toma de decisiones gerenciales asegurando que se proporciona información confiable y segura. Este proceso de TI también es necesario para incrementar la responsabilidad sobre la integridad y seguridad de los datos y para mejorar la efectividad y control de la información compartida a lo largo de las aplicaciones y de las entidades (CobIT v4.1 - PO2: Definir la arquitectura de la información). La desatención de las buenas prácticas antes mencionadas, puede: i) impactar en la detección oportuna de posibles cambios indebidos a los datos del sistema; ii) comprometer la integridad de la información; iii) dar lugar a la posibilidad de que existan datos inconsistentes; iv) dar lugar a ineficientes controles de aplicación; y v) dificultar la compartición de datos entre aplicaciones, sistemas y entidades. Concurrentemente, se pone en	privilegios se encuentra penada por la ley 26.388 de delitos informáticos. Respecto de las recomendaciones de “buenas prácticas” ISO 27002 y CoBIT 4.1, se reitera lo dicho en 4.2.1.	



Auditoría General de la Nación

Sección del Informe	Comentario del Auditado	Análisis del Comentario
riesgo el cumplimiento de la política de seguridad del organismo, la gestión de incidentes, las mejoras de la seguridad de la información y el cumplimiento de regulaciones internas y externas. Asimismo, la información de auditoría necesita ser protegida debido a que, si los datos son modificados o borrados, su existencia puede crear una falsa sensación de seguridad.		
4.3. Continuidad de las Operaciones Organizacionales 4.3.1. La DGTIC no ha incorporado a las aplicaciones críticas de la organización, entre ellas al SIGADE, dentro del Plan de Recuperación ante Desastres oficialmente vigente dentro del período auditado. Este escenario implica un riesgo crítico y de alto impacto sobre la disponibilidad de los sistemas de información críticos del organismo ante una interrupción de los servicios de TI, sobre los cuales todas las áreas operativas tienen una alta dependencia. A partir del análisis efectuado sobre la documentación provista por la DGTIC, y de las entrevistas mantenidas con el Director de la DGTIC y con el Director de Explotación de la DGTIC, se constata que el Plan de Recuperación ante Desastres vigente en el organismo al momento de esta auditoría no incluye a los sistemas de información críticos del organismo, entre ellos al SIGADE, objeto de esta auditoría. En función de lo que establecen las buenas prácticas en la materia (ISO 22.301 - Directrices para garantizar la Continuidad del Negocio; ISO 24.762 - Directrices para asegurar la continuidad de los servicios de TI; ISO 27.001 - Sistemas de gestión de la seguridad de la información; CobIT v4.1 - DS4: Garantizar la continuidad del servicio), un Plan de Recuperación ante Desastres (DRP, por sus siglas en inglés) es un proceso de	Al auditor se le ha comentado en una entrevista que el sistema SIGADE fue asimilado por la DGTIC luego de estar en fase de implementación el plan de recuperación ante desastres y que se incluiría al SIGADE en la próxima prueba del plan.	El comentario del auditado no desconoce ni contradice lo observado. Toda mejora posterior a la finalización de las tareas de campo será tomada en cuenta en oportunidad de autorizarse futuras auditorías. Por lo tanto, se mantiene el hallazgo.



Auditoría General de la Nación

Sección del Informe	Comentario del Auditado	Análisis del Comentario
restitución que cubre los datos, el hardware y el software crítico, para que un negocio pueda comenzar de nuevo sus operaciones en caso de ocurrencia de un desastre natural, errores humanos, ciberataques o ataques causados por terceros de cualquier tipo, que atenten contra la continuidad del funcionamiento de la organización. En este proceso no solo intervienen las áreas técnicas responsables de su ejecución sino también las áreas críticas de la organización, incluida la alta dirección, que deben formar parte de un comité de crisis para actuar al momento de su activación. Conforme las mejores prácticas anteriormente indicadas, un Plan de Recuperación ante Desastres debe contener, desarrollar y ejecutar como mínimo los siguientes pasos: a) desarrollar una política de continuidad del negocio, b) realizar una evaluación de riesgos, c) realizar un análisis de impacto al negocio, d) desarrollar estrategias de recuperación y continuidad del negocio, e) concientizar, capacitar y probar los planes, f) mantener y mejorar el plan de recuperación ante desastres. Si bien se pudo verificar que la DGTIC cuenta con un DRP y un plan de pruebas elaborado y ejecutado de acuerdo al marco metodológico que indican las buenas prácticas en la materia, en caso de que se requiera activarlo, este plan resulta incompleto e insuficiente para asegurar la disponibilidad de la información crítica del organismo debido a que el DRP vigente al momento de esta auditoría no contempla un aspecto central: garantizar la disponibilidad del software crítico de la organización. Abarcar este plan adecuadamente ofrece la ventaja de responder de forma planeada y proactiva ante una catástrofe y minimizar su impacto en los objetivos y misión de la organización y sobre los sistemas de información que constituyen el soporte		



Auditoría General de la Nación

Sección del Informe	Comentario del Auditado	Análisis del Comentario
informático a los servicios que ésta presta. Que la DGTIC, a cargo de la gestión y administración de la infraestructura tecnológica de los sistemas de información del organismo, no contemple a los sistemas de información críticos, entre los cuales se encuentra el SIGADE –objeto de esta auditoría– dentro de su Plan de Recuperación ante Desastres acorde a lo que establecen las buenas prácticas y su correspondiente plan de pruebas, documentación de simulacros y ajustes continuos, pone en riesgo la disponibilidad de las aplicaciones y de la información que dan soporte a los procesos operativos que son relevantes para la organización, incluidos a los ejecutados por la DADP.		
4.3.2. <i>La DGTIC no ha incorporado, en sus políticas y procedimientos de resguardo, procesos de control que garanticen la identificación y el resguardo exitoso de los documentos (planillas de cálculo y otros documentos electrónicos) que son considerados clave para los procesos de seguimiento y control de los instrumentos de deuda registrados en el SIGADE, lo que pone en riesgo la disponibilidad de la información utilizada por la DADP en sus procesos operacionales diarios.</i> En función del análisis de la documentación técnica provista por la DGTIC y de las entrevistas mantenidas con personal técnico de la Dirección de Explotación de la DGTIC y con personal operativo de las distintas coordinaciones de la DADP, se constató que, si bien se realizan las copias de resguardo sobre las carpetas compartidas de la DADP alojadas en los servidores de archivos, las políticas y procedimientos de back-ups aplicados por la DGTIC carecen de procedimientos de identificación y de control de resguardo sobre los documentos administrados y almacenados por los usuarios de la DADP en las	La DGTIC posee procesos implementados de pruebas de recuperación de la información existente en cintas de respaldo, y es un proceso que se ejecuta de manera regular. Dada la escala y magnitud de servicios críticos manejados por esta Dirección, es materialmente imposible verificar por cada sistema crítico la recuperación exitosa de un respaldo específico. Lo materialmente posible es tomar muestras aleatorias del respaldo general del centro de cómputos y verificar su disponibilidad, y es lo que se ejecuta en forma cotidiana. Se documentará el mismo.	El comentario del auditado no desconoce ni contradice lo observado, por lo tanto, se mantiene el hallazgo.



Auditoría General de la Nación

Sección del Informe	Comentario del Auditado	Análisis del Comentario
carpetas compartidas asignadas. Según el Manual de Procesos (Disposición N°1/2015, emitido por el ex Ministerio de Economía y Finanzas Públicas, actual Ministerio de Economía) estos documentos son esenciales para los procesos de seguimiento y control de los instrumentos de deuda registrados en el SIGADE. Las buenas prácticas sobre políticas y procedimientos de back-ups y pruebas de restauración establecen que se debe garantizar la posesión de copias de resguardo de toda la información crítica utilizada por la organización, relevando de manera continua las necesidades de resguardo de información con las áreas usuarias. Además, se debe someter a la solución de back-up y recuperación de datos a pruebas formalizadas en forma periódica con la debida documentación de los resultados obtenidos en ellas, con la aceptación y control de las áreas usuarias. Estos tests deben poner a prueba el funcionamiento de la tecnología utilizada, y es la forma más adecuada de detectar y resolver posibles fallos antes de que ocurra un incidente real (ISO 27.001 - Aspectos de seguridad - Información para la gestión de continuidad de negocio y CobIT v4.1 - DS4: Garantizar la continuidad del servicio). Aplicar procedimientos de back-up que no garanticen la identificación y el resguardo exitoso de la totalidad de los documentos críticos que la DADP almacena en las carpetas compartidas, pone en riesgo la disponibilidad de dicha información ante un incidente que requiera aplicar una restauración.		
4.4. Operaciones de TI 4.4.1. El Manual de Procesos utilizado por la DADP como guía para la ejecución de los procesos operativos de registración, seguimiento y control de los instrumentos de deuda se encuentra	El Manual de Procesos utilizado por la DADP como guía para la ejecución de los procesos operativos de registración, seguimiento y control de los instrumentos de deuda se encuentra desactualizado, lo que conlleva el riesgo de los agentes intervinientes en la ejecución	El comentario del auditado no desconoce ni contradice lo observado, por lo tanto, se mantiene el hallazgo.



Auditoría General de la Nación

Sección del Informe	Comentario del Auditado	Análisis del Comentario
<i>desactualizado, lo que conlleva el riesgo de que los agentes intervinientes en la ejecución diaria de los procedimientos de registración, seguimiento y control de los instrumentos de deuda apliquen acciones atemporales.</i> Del análisis de la documentación técnica provista por la DADP (Manual de Procesos, mapa de procesos ejecutados, herramientas ofimáticas utilizadas y de los sistemas de información intervinientes) y de las entrevistas mantenidas con la DADP, con las distintas coordinaciones y usuarios de la DADP, se verificó que el Manual de Procesos formalizado a través de la Disposición N° 1/2015 no ha sufrido modificaciones desde su aprobación, lo que implica que todos los usuarios de distintos perfiles y funciones de la DADP estén utilizando un manual para la ejecución de los procesos de registración, seguimiento y control de los instrumentos de deuda que se encuentra desactualizado y que no contempla nuevos procesos, aplicaciones y documentos ofimáticos que se fueron incorporando desde la aprobación del manual hasta la fecha del fin del período auditado. Las buenas prácticas orientadas a procedimientos e instrucciones de administración de procesos de negocio indican que se deben definir, implementar y mantener procedimientos estándar para operaciones y garantizar que el personal operativo está familiarizado con todas las tareas de operación relativas a ellos (CobIT v4.1 - DS13.1: Procedimientos e Instrucciones de Operación). La gestión de procesos de negocio (BPM, por sus siglas en inglés), en el apartado “Mejora de Procesos”, establece que todos los procesos de negocio se degradan, se transforman o cambian con el tiempo debido a que surgen nuevas necesidades empresariales, nuevas tecnologías o nuevas reglas	diaria de los procedimientos de registración, seguimiento y control de los instrumentos de deuda apliquen acciones temporales. Que el Manual de Procesos se encuentre desactualizado no implica que los procesos que allí se describen no se cumplan o que se cumplan parcialmente. La utilización del sistema GDE y la integración del SIGADE al módulo de gastos del SIDIF, han significado cambios que no alteran la esencia de los procesos del Manual, lo cual tampoco implica que se desconozca la necesidad de su actualización.	



Auditoría General de la Nación

Sección del Informe	Comentario del Auditado	Análisis del Comentario
establecidas por el contexto. Para afrontar estas variaciones dinámicas sobre los procesos de negocio es importante que la organización implemente prácticas metodológicas, con inversión en tiempo y en recursos dedicados, para garantizar la mejora y actualización continua de los procesos clave del negocio. La falta de prácticas de mantenimiento y actualización continua del Manual de Procesos — considerado una guía clave para la DADP en la ejecución diaria de los procedimientos de registración, seguimiento y control de los instrumentos de deuda—, puede generar acciones erróneas por su atemporalidad por parte de los agentes intervinientes en cuestiones operativas y en la toma de decisiones de los responsables jerárquicos de las distintas coordinaciones de la DADP, al guiarse de procesos desactualizados.		
4.5. Adquisiciones y contratación de TI 4.5.1. <i>No se encuentran formalizados los acuerdos de niveles de servicio entre el organismo y la UNCTAD, proveedor del servicio de soporte y mantenimiento continuo del SIGADE, por lo que resulta dificultoso que la DADP y la DGTIC puedan gestionar y controlar adecuadamente la calidad de servicio sobre las acciones correctivas, adaptativas y evolutivas que ejecuta el proveedor en el SIGADE. A partir de la evaluación de la información técnica provista por la DADP y de las entrevistas mantenidas con la DADP y con las áreas técnicas de la DGTIC que brindan soporte sobre el SIGADE, se constató que el organismo no cuenta con acuerdos de niveles de servicio de soporte y mantenimiento continuo del SIGADE formalizados con la UNCTAD. Si bien las condiciones generales del servicio de soporte provisto se cumplen con razonabilidad, no se encuentran</i>	Sin comentarios.	Se mantiene el hallazgo.



Auditoría General de la Nación

Sección del Informe	Comentario del Auditado	Análisis del Comentario
documentados y formalizados los acuerdos de niveles de servicios con la UNCTAD en referencia al soporte sobre el SIGADE, que permitan garantizar respuesta técnica y funcional, en tiempo y forma, del proveedor del servicio a la demanda de disponibilidad requerida por los procesos operativos de gestión de la deuda pública, en especial sobre aquellos que se aplican específicamente en nuestro país (localizaciones funcionales). Las buenas prácticas en gestión de proveedores de TI establecen que se debe definir y actualizar de manera continua un marco de trabajo que brinde un proceso formal de administración de niveles de servicio entre el cliente y el prestador de servicio. El marco de trabajo mantiene una alineación continua con los requerimientos y las prioridades del negocio y facilita el entendimiento común entre el cliente y el(los) prestador(es) de servicio. El marco de trabajo incluye procesos para la creación de requerimientos de servicio, definiciones de servicio, acuerdos de niveles de servicio, acuerdos de niveles de operación y las fuentes de financiamiento. Estos atributos están organizados en un catálogo de servicios. El marco de trabajo define la estructura organizacional para la administración del nivel de servicio, incluyendo los roles, tareas y responsabilidades de los proveedores externos e internos y de los clientes (CobIT v4.1 - DS1.1: Marco de trabajo de la administración de los niveles de servicio, ITIL - capítulo “Gestión del Nivel de Servicio”). La carencia de un compromiso plasmado en un acuerdo de niveles de servicio debidamente actualizado impide al organismo tener garantías de la calidad y, principalmente, la medición de los alcances pactados del servicio en aspectos tales como tiempo de respuesta, disponibilidad horaria, documentación disponible, personal asignado al		



Auditoría General de la Nación

Sección del Informe	Comentario del Auditado	Análisis del Comentario
servicio, respuesta a nuevos requerimientos funcionales sobre el sistema, etc., lo que indefectiblemente conduce a una administración informal de la disponibilidad del SIGADE y de sus condiciones frente a los requerimientos críticos por parte de la DADP como principal área usuaria del sistema.		
4.6. Sistemas de información 4.6.1. El uso de planillas de cálculo para el control de la información que se registra en el SIGADE durante el ciclo de vida de los instrumentos de deuda pública, no garantiza la separación de funciones en el control cruzado, ni la integridad, confidencialidad y la disponibilidad de la información que estas planillas contienen. La falta de aplicaciones que den soporte automatizado a los procesos operativos de la DADP pone en riesgo la eficiencia en el logro de los objetivos establecidos en el Manual de Procesos para la registración, el seguimiento y control de los instrumentos de deuda pública. En base a los relevamientos realizados con usuarios del SIGADE de distintos niveles jerárquicos, y al análisis de los documentos técnicos provistos por la DADP, entre otros, el Manual de Procesos (Disposición N° 1/2015), se verificó que la DADP utiliza a diario un catálogo de planillas de cálculo, almacenadas y administradas en carpetas compartidas – alojadas en servidores de red corporativos– por cada coordinación. Entre otros, la información generada por estas planillas se utiliza para llevar a cabo actividades de seguimiento y controles – pre y pos registro– sobre la información ingresada en el SIGADE durante todo el ciclo de vida de los instrumentos de deuda pública, y para conciliar y corregir/ajustar la información de salida generada por el SIGADE. A partir del análisis de este escenario, esta	Las áreas que requieren desarrollos y/o correcciones de sistemas y/o mejoras, efectúan el pedido a la Subsecretaría de Administración y Normalización Patrimonial (de la cual depende la DGTIC), quien en conjunto con la DGTIC evalúa, en base a los proyectos y desarrollos en curso existentes y sus prioridades, la disponibilidad de recursos para el nuevo requerimiento. La DGTIC elabora y obtiene aprobación por parte de las autoridades de su Plan Estratégico de TI de 3 años (corto, mediano y largo plazo), según la normativa vigente. Su actualización se aprueba anualmente. Cualquier modificación al Plan Estratégico requiere de una reprogramación, la cual debe ser aprobada nuevamente por las autoridades. Hasta la fecha de esta respuesta al informe de auditoría, la DGTIC no tiene ni tuvo pedidos del área sustantiva relacionados con el tema mencionado.	El comentario del auditado no desconoce ni contradice lo observado. Se reitera lo comentado en 4.1.1. Por lo tanto, se mantiene el hallazgo.



Auditoría General de la Nación

Sección del Informe	Comentario del Auditado	Análisis del Comentario
auditoría constató que: i) dentro de cada coordinación, todos los usuarios tienen acceso de lectura y escritura sobre todas las planillas allí almacenadas. Esta situación refleja ineficiencia en la segregación de acceso a la información según los perfiles y las funciones de cada perfil; ii) el método aplicado por la DADP para el control y seguimiento sobre las intervenciones de los usuarios a la información contenida en las planillas de cálculo, y con el objetivo de establecer una trazabilidad de las operaciones ejecutadas por aquellos, es que cada usuario “firma” escribiendo sus iniciales en una celda, toda vez que efectúe un cambio sobre la información contenida en las planillas. Este método es insuficiente, ineficiente y vulnerable, en consecuencia, su aplicación no brinda garantías sobre la integridad de la información; iii) la información contenida en estas planillas, en determinadas circunstancias operativas, es utilizada por la DADP como dato empírico para petitionar intervenciones manuales a la base de datos del SIGADE a fin de corregir/ajustar las inconsistencias que no puedan corregirse a través del sistema – ejemplo: ajustes de diferencias generadas por la cantidad acotada de decimales que ofrece el SIGADE a nivel usuario, respecto de la cantidad de decimales que requieren algunos instrumentos de deuda–; iv) según lo indicado en el Manual de Procesos de la DADP y por la ponderación operativa señalada por los usuarios de esta dirección, la información que contienen las planillas de cálculo es relevante y esencial para la ejecución de los procesos administrativos de la DADP. No obstante, y en consonancia con lo indicado en el hallazgo 4.1.1., la DGTIC no ha realizado un relevamiento de requerimientos tecnológicos y funcionales en la		



Auditoría General de la Nación

Sección del Informe	Comentario del Auditado	Análisis del Comentario
DADP, a fin de reemplazar este catálogo de planillas de cálculo por un aplicativo o por una herramienta provista por el propio SIGADE que permita realizar los controles y seguimientos –pre y pos registro– de la información imputada en el sistema, subsanando las debilidades y limitaciones de confidencialidad, integridad y disponibilidad que presentan las planillas de cálculos; y v) del análisis del manual de usuarios del SIGADE, esta auditoría pudo verificar que la versión 6 del sistema –en producción al momento de esta auditoría– cuenta con herramientas que permiten adjuntar archivos de trabajo de cualquier formato (Word, Excel o PDF, entre otros) a un instrumento de deuda pública registrado en la base de datos. Se trata de una funcionalidad que ofrece la posibilidad de almacenar todos los documentos contractuales de un acuerdo de préstamo o de un título de deuda para referencias o consultas rápidas por parte de los agentes de la DADP. Dicha funcionalidad no es utilizada por los usuarios del sistema. Las buenas prácticas en adquisición e implantación de aplicativos establecen que se deben identificar los requerimientos funcionales y de control del negocio a fin de traducirlos en soluciones automatizadas efectivas y eficientes, que satisfagan los requerimientos del usuario y consideren los requerimientos de seguridad y control desde el principio, aprovechando la inversión en tecnología existente (CobIT v4.1 – AI: Adquisición e implantación). Asimismo, las buenas prácticas en adquisición y mantención de software aplicativo establecen, entre otras cuestiones, que las aplicaciones deben estar disponibles de acuerdo con los requerimientos del negocio, y que este proceso debe cubrir el diseño de las aplicaciones, la inclusión apropiada de controles aplicativos y requerimientos de		



Auditoría General de la Nación

Sección del Informe	Comentario del Auditado	Análisis del Comentario
seguridad (CobIT v4.1 – AI2: Adquirir y mantener software aplicativo). En cuanto a facilitar la operación y el uso de los aplicativos, las buenas prácticas establecen que el conocimiento sobre los sistemas debe estar disponible y que este proceso requiere la generación de documentación y manuales para usuarios y para TI, así como se debe proporcionar entrenamiento para garantizar el uso y la operación correctos de las aplicaciones (CobIT v4.1 – AI4: Facilitar la operación y el uso). Las planillas de cálculo, herramientas clave para el control interno de la DADP, no cuentan con la seguridad necesaria para garantizar la separación de funciones en el control cruzado, la integridad de la información que contienen (datos y fórmulas de cálculo), la confidencialidad y la disponibilidad de la información de control interno. La falta de un relevamiento por parte de la DGTIC en conjunto con la DADP respecto a las necesidades técnicas y funcionales para reemplazar las planillas de cálculo dificulta que la organización apoye su operatividad de manera adecuada y segura con aplicaciones automatizadas que faciliten el logro de los objetivos operacionales de la DADP, considerando siempre la premisa de integridad, confidencialidad y disponibilidad de la información garantizando su eficiente control interno y cruzado.		
4.6.2. <i>Se ejecutan procedimientos de rectificaciones de datos de instrumentos de deuda pública por fuera del SIGADE, lo que no brinda garantías sobre la integridad de la información y conlleva el riesgo inherente de modificaciones no autorizadas, malintencionadas o erróneas sobre la base de datos del SIGADE.</i> Del análisis de la información recibida y de las entrevistas mantenidas con los administradores del SIGADE, esta auditoría constató que: i) los	Dadas las características de deuda argentina, la única forma de reflejar en el sistema ciertos cambios específicos es a través de sentencias SQL. Las modificaciones a la base se solicitan por ticket a la Mesa de Servicios de la DGTIC, que los deriva al Administrador, quien recibe la captura de dichos tickets. En todos los tickets figura: - Usuario del área sustantiva que solicita el cambio; - La descripción detallada del cambio;	El comentario del auditado no desconoce ni contradice lo observado, por lo tanto, se mantiene el hallazgo.



Auditoría General de la Nación

Sección del Informe	Comentario del Auditado	Análisis del Comentario
administradores del sistema llevan a cabo rectificaciones de datos en la base de datos del SIGADE por fuera del sistema –utilizando sentencias SQL– a pedido de los usuarios de la DADP por medio de la Mesa de Servicios; ii) para efectuar las rectificaciones de datos, los administradores del sistema se registran con un usuario administrador genérico, lo que no permite identificar al autor de estas operaciones; iii) no existe un documento formal que establezca los procedimientos oficiales a aplicar para efectuar intervenciones manuales a la base de datos del SIGADE por solicitud de los usuarios; y iv) no es posible obtener la trazabilidad de las rectificaciones de datos realizadas por los administradores del sistema ya que no hay información en las tablas de auditoría que permita vincular cada transacción de intervención manual con el ticket de la Mesa de Servicios que contiene la petición del usuario que la originó. A continuación, se detallan algunos ejemplos de solicitudes de intervenciones manuales a la base de datos del SIGADE: i) usuario solicita inserción de varios registros de patrones, por lo cual se deben generar los scripts de los inserts y su posterior ejecución, en la base de datos SIGADE producción; ii) usuario solicita la eliminación del SIGADE Nro. xxx, borrarlo en todas las tablas donde impacta ese número de SIGADE; iii) usuario solicita la modificación de los montos de 5.287 patrones para el SIGADE Nro. xxx. Preparación de los scripts para el impacto de esos cambios y ejecución de los scripts en la base de datos SIGADE de producción; iv) usuario solicita la creación de un script para insertar un patrón irregular de principal (tanto en el patrón irregular como en la tabla de amortización) del SIGADE Nro. xxx, tramo xx con	- Administrador que la realizó, fecha y hora. Con respecto al uso genérico del usuario administrador, algunas intervenciones sólo se pueden realizar con los privilegios del usuario Administrador del sistema (usuario DMFASVWS), ejemplo actualizar la versión del sistema y/o modificar comportamientos del sistema a través del panel de control del sistema. Para las demás operaciones, cada administrador tiene su usuario creado en el sistema. Las sentencias SQL pasarán a ejecutarse con el usuario de cada administrador.	



Auditoría General de la Nación

Sección del Informe	Comentario del Auditado	Análisis del Comentario
fecha xx.xx.xxxx y monto xx.xxx.xxx). Según las buenas prácticas en administración de bases de datos, el concepto de separación de funciones dicta que las tareas de administración deben ser divididas entre varios usuarios y no entre un sólo individuo con privilegios ilimitados. Asimismo, la división de tareas como administración, seguridad y operaciones hace que sea menos probable que los usuarios abusen de sus privilegios y también reduce aún más la superficie de ataque de cuentas comprometidas. La función del DBA es la de proteger los datos, y no de procesarlos. El DBA no es un usuario del sistema, en consecuencia, no administra valores de datos sino la actividad de ellos (CobIT v4.1 - PO4.11: Segregación de funciones). Por otro lado, las buenas prácticas en seguridad de la información establecen que los administradores no deben utilizar cuentas genéricas o compartidas y las actividades de los DBA con privilegios excesivos deben ser supervisadas de cerca. Además, se debe prestar consideración para establecer los roles de acceso de usuarios basados en los requerimientos de la actividad que desempeñan, así como es necesario el uso de procedimientos de seguimiento y control para asegurar que los usuarios realicen solamente las actividades para las cuales han sido explícitamente autorizados (CobIT v4.1 - PO4.10: Supervisión, ISO 27002 - 11.6.1 Restricción de acceso a la información). De igual manera, las buenas prácticas en administración de identidad establecen que todos los tipos de usuarios (operadores, usuarios de sistema y administradores de bases de datos) y su actividad en el sistema deben ser identificables de manera única para trazar las actividades del individuo responsable (CobIT v4.1 - DS5.3: Administración de identidad). Por último, las		



Auditoría General de la Nación

Sección del Informe	Comentario del Auditado	Análisis del Comentario
buenas prácticas en gestión de operaciones recomiendan que los procedimientos operativos se documenten, se mantengan y se encuentren disponibles para todos los usuarios que los necesiten, y que además se traten como documentos formales y los cambios sean autorizados por la alta dirección (ISO 27002 - 10.1.1 Documentación de los procedimientos administrativos). El no cumplimiento de las buenas prácticas señaladas puede dar lugar a cambios no autorizados, malintencionados o a errores involuntarios en los datos, poniendo en riesgo la integridad y consistencia de los datos almacenados en la base de datos del SIGADE. Asimismo, las cuentas compartidas y/o genéricas eliminan la responsabilidad, aumentan el riesgo y hacen que la auditoría de la actividad del/los administrador/es sea esencialmente imposible de seguir y/o controlar. El uso inadecuado de los privilegios de administración del sistema puede ser el factor más importante que contribuya a fallas o brechas de los sistemas. Concurrentemente, la situación observada provoca: i) que no se ejecuten de manera efectiva y eficiente las responsabilidades y los roles clave de TI, y un control inapropiado de dichas funciones; ii) un mal funcionamiento de los procesos de TI; y iii) que la administración de accesos no cumpla los requerimientos de confidencialidad, integridad y disponibilidad de la información del sistema, lo que puede causar una inadecuada investigación de actividades de acceso inapropiadas y una inadecuada protección de los activos de información.		